



Cyber security legislation – not for exam

ISM Master, Overview 2024-2025

AGENDA

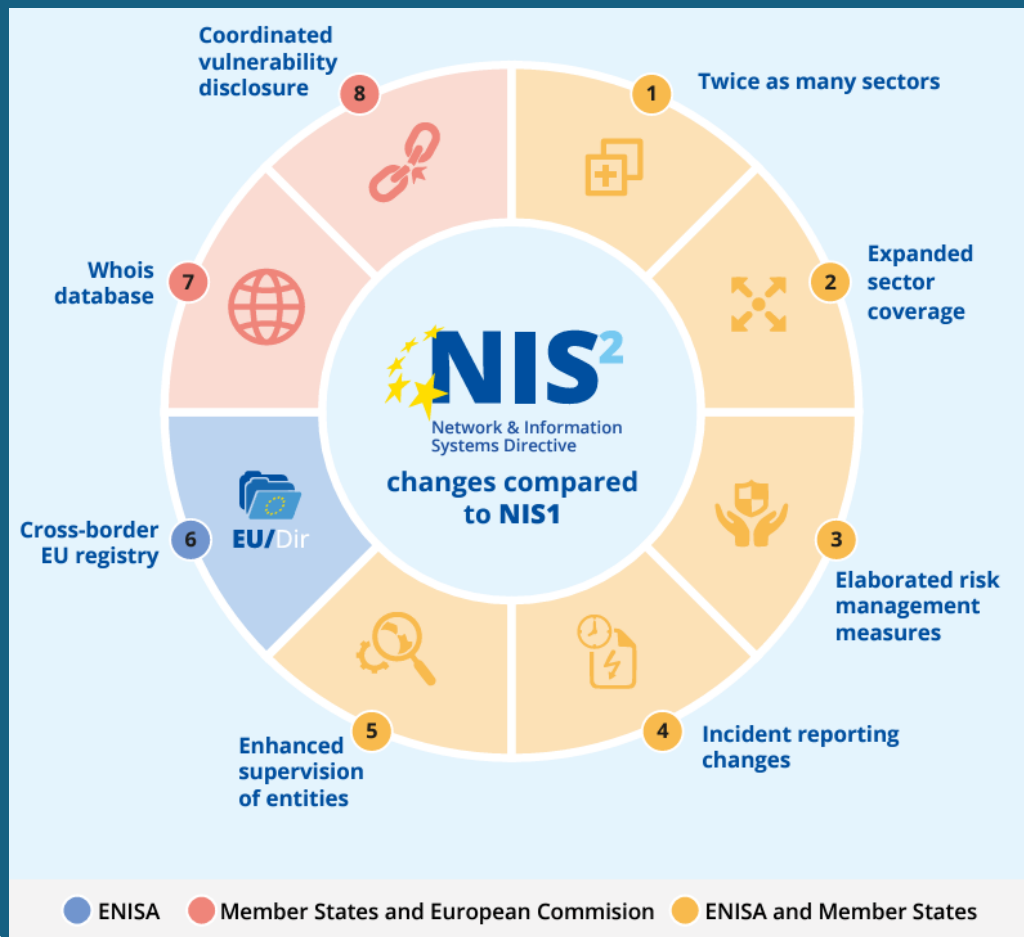
NIS 2

Artificial Intelligence Act

DORA

Cyber Resilience Act

NIS 2 Directive



7 Whois database



Member States are expected to maintain a dedicated database of domain name registration data, including contact details for registrants and administrators, to enhance DNS security, stability, and resilience.

8 Coordinated vulnerability disclosure



A structured process for reporting vulnerabilities to manufacturers or service providers, is introduced, to ensure vulnerabilities are addressed and resolved before being made public.

NIS 2 Directive

1 Twice as many sectors



With NIS2 more sectors / subsectors are in scope based on their degree of digitalization, interconnectedness and how crucial they are for the economy and society.

2 Expanded sector coverage



A size threshold rule distinguishes essential from important entities, while Member States can include smaller, high-risk entities.

3 Elaborated risk management measures



An expanded list of proportional, all-hazards cybersecurity risk management measures is introduced, along with increased responsibilities for top management.

4 Incident reporting changes



More structured incident notification obligations apply to in-scope organisations, with specific deadlines for incidents which have a 'significant impact' on the provision of their services.

5 Supervision of entities



A more coherent framework for stronger supervision is introduced, that encompasses minimum supervisory means, distinct regimes for essential and important entities, and cross-border collaboration mechanisms.

6 Cross-border EU Registry



An EU-wide registry for cross-border entities where Member States will register their main establishments and branches is foreseen for enhanced supervision.

NIS 2 Directive



High criticality sectors



Other critical sectors

NIS 2 Directive

Entities within the identified sectors are categorized as **essential entities** or **important entities**

depending on factors such as size, sector and criticality.

Essential entities

- **High criticality sectors** - companies that exceed medium-sized threshold
- **Qualified trust service providers and top-level domain name registries**, regardless of size
- **DNS service providers**, regardless of size
- Providers of ECN or ECS - medium-sized and large companies

Important entities

- **High criticality sectors** - companies that are small or medium
- **Other critical sectors** - companies that exceed medium-sized threshold
- Providers of ECN or ECS - small companies

■ KEEP IN MIND

■ 1

All entities are required to implement risk management measures.

■ 2

All entities are required to report significant cybersecurity incidents.

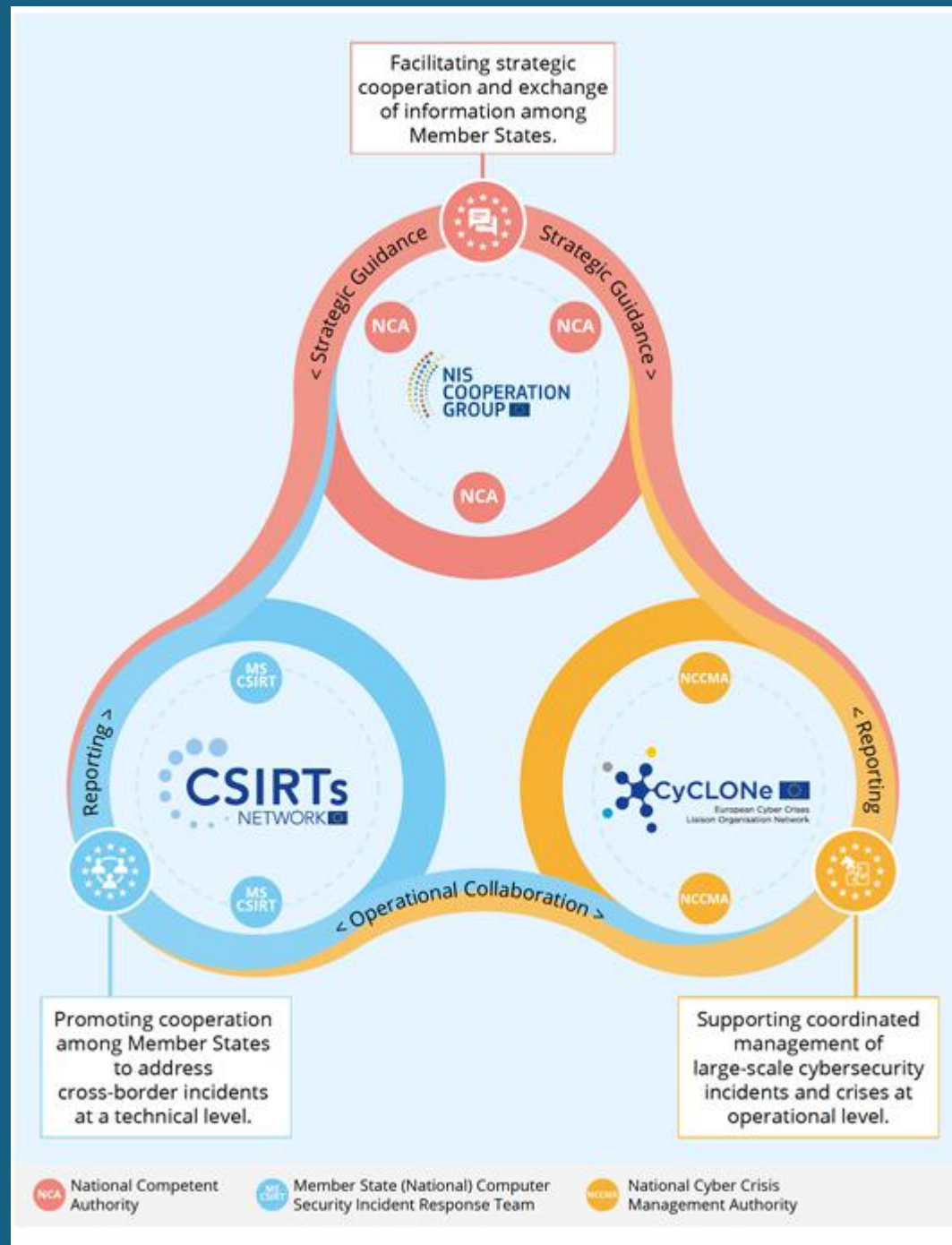
■ 3

Essential entities are subject to ex ante & ex post supervision.

■ 4

Important entities are subject to ex post supervision only.

NIS 2 Directive



Source: ENISA

NIS 2 Directive

■ WHAT IS AN INCIDENT?



■ WHEN SHOULD I REPORT?

When becoming aware of a **significant incident**:

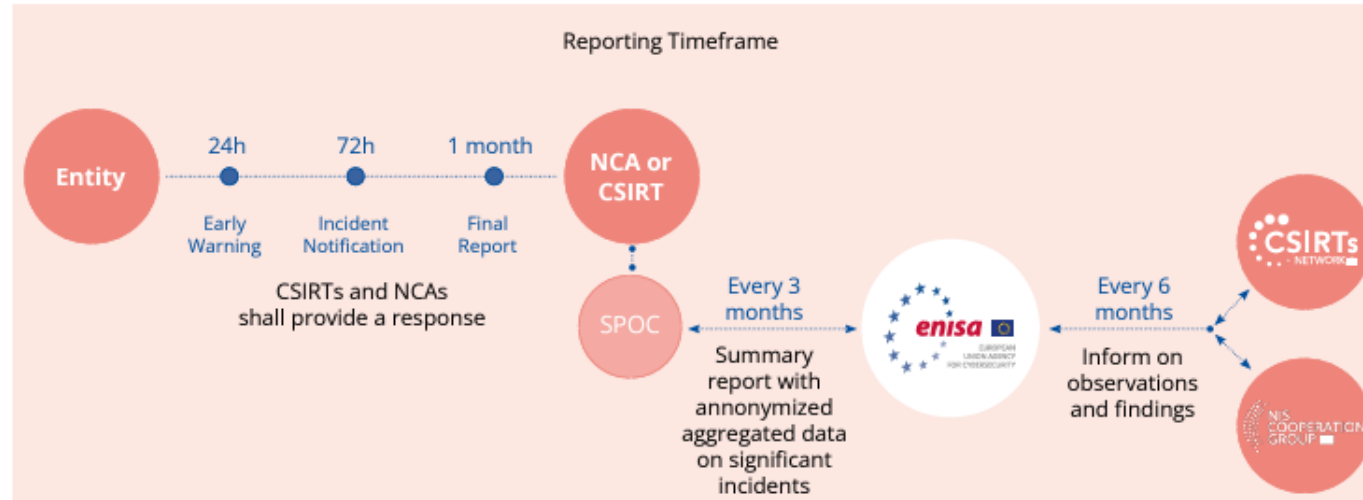
- 

■ 1
An event that has caused/could cause severe operational disruption or financial loss.
- 

■ 2
An event that has caused or could cause damage to natural or legal persons.

NIS 2 Directive

■ A REPORTABLE INCIDENT HAPPENED – NOW WHAT?



■ 1

Where applicable, Member States shall ensure that entities communicate to the recipients of their services that are potentially affected by a significant cyber threat any measures or remedies that those recipients are able to take in response to that threat.

Where appropriate, the entities shall also inform those recipients of the significant cyber threat itself.



■ 2

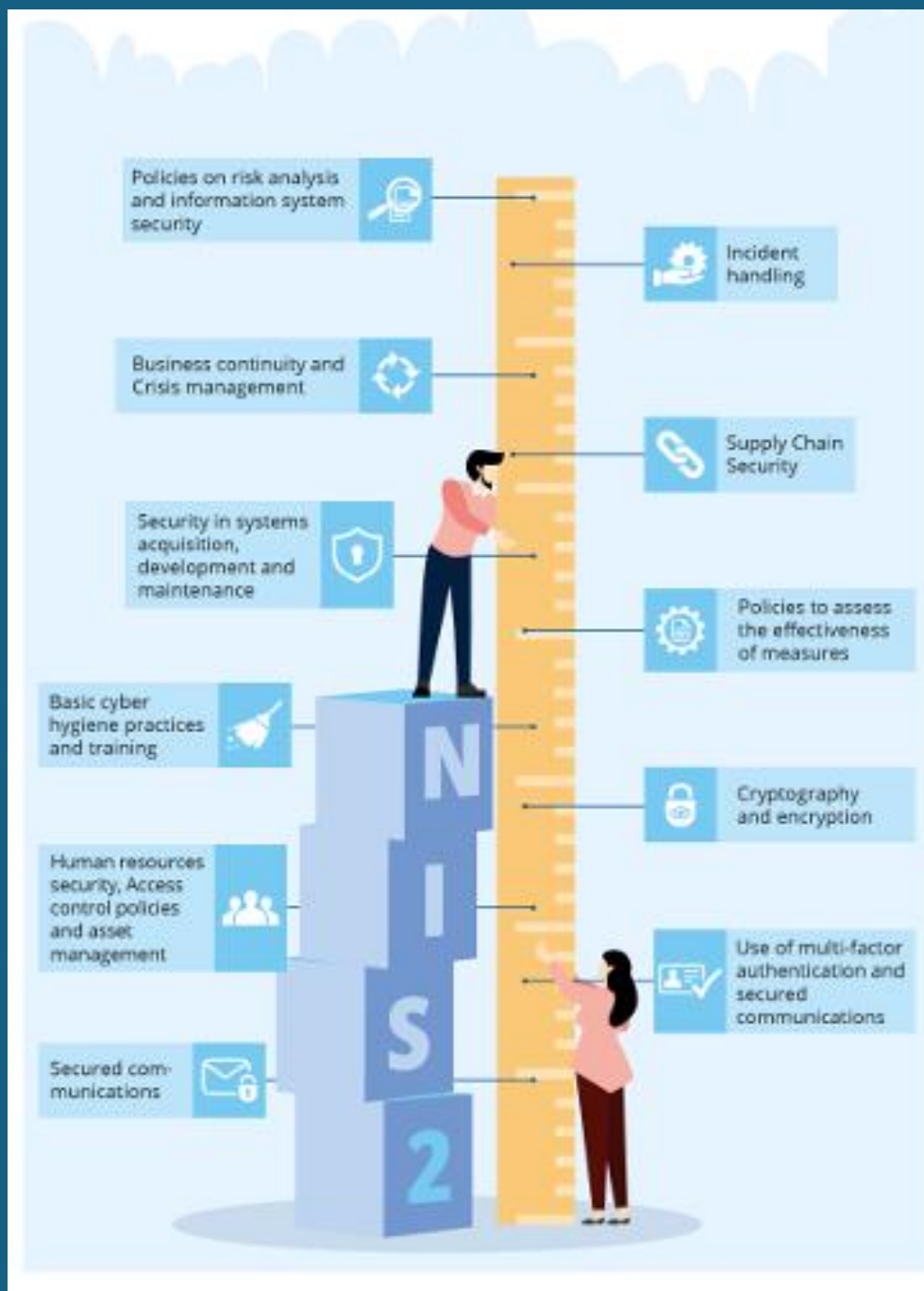
When in the public interest, Member states may inform the public or ask the entity to do so.



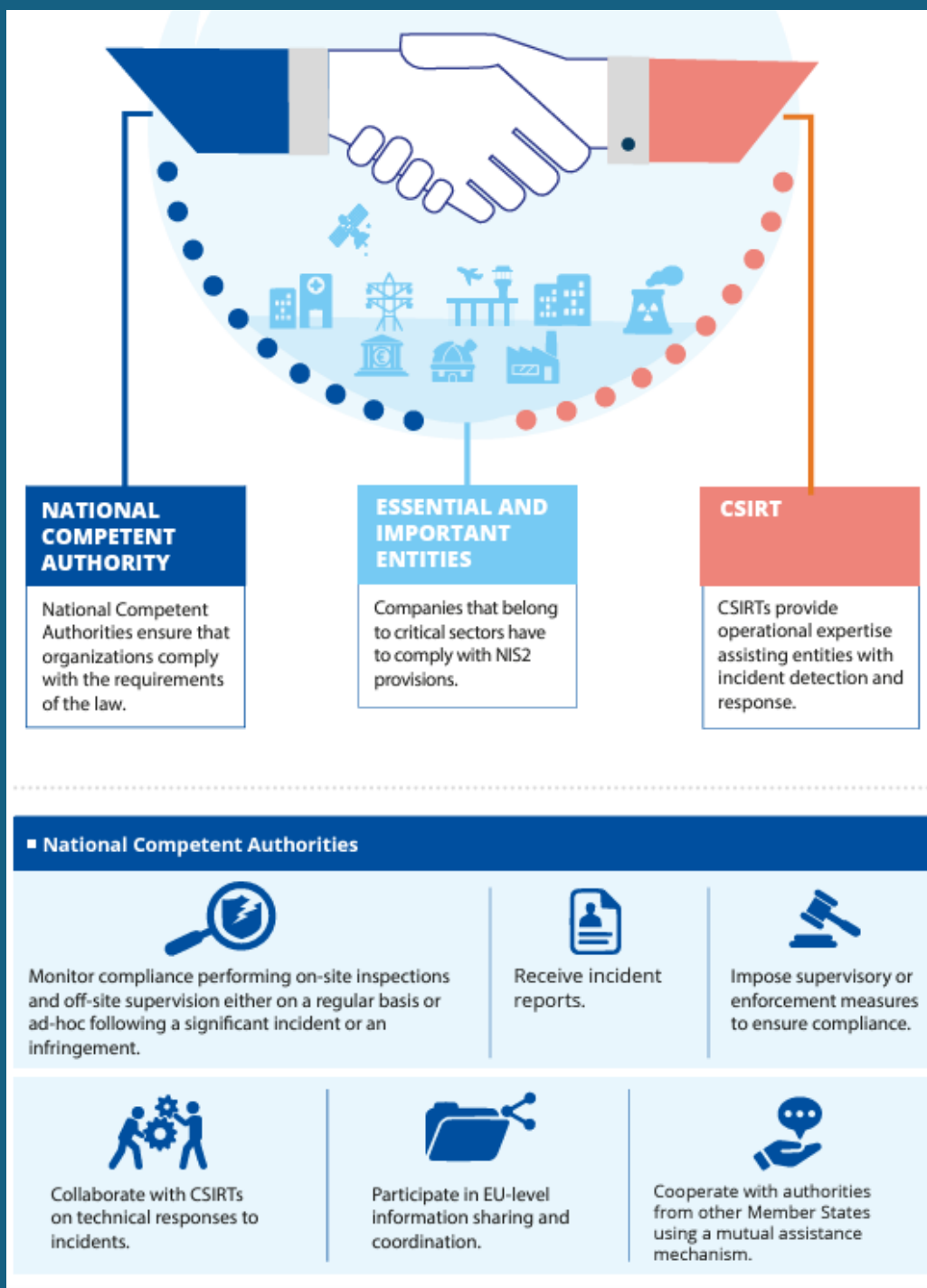
■ 3

If the significant incident concerns two or more Member States, the CSIRT, the competent authority or the single point of contact shall inform, the other affected Member States and ENISA.

NIS 2 Directive



NIS 2 Directive



Source: ENISA

NIS 2 Directive

■ CSIRTs



Detect, analyse and respond to cyber incidents.



Coordinate technical responses to mitigate impact.



Disseminate information about threats and vulnerabilities.



Facilitate EU cooperation and information exchange.



Enhance preparedness and awareness among entities.

■ Essential and Important entities



Implement security measures.



Evidence compliance.



Report significant incidents and on a voluntary basis non-significant incidents and near-misses



The details of supervision depend on national legislation.



Essential entities are subject to a comprehensive ex ante and ex post supervisory regime, while important entities are subject to ex post only, supervisory regime.



Where an entity provides services in more than one Member States, or provides services in one or more Member States and its network and information systems are located in one or more other Member States, the competent authorities of the Member States concerned shall cooperate with and assist each other as necessary, using a mutual assistance mechanism.

NIS 2 Directive

VULNERABILITY DISCLOSURE



NIS2 introduces Coordinated Vulnerability Disclosure, a structured disclosure process and a European database with information about disclosed vulnerabilities.



* The national CVD policy and procedure ensures disclosure is done carefully and timely, so that there is enough time for affected entities to find a patch or a solution, before it is disclosed publicly.

■ 1

A national CVD policy is required by the NIS Directive, to ensure that ethical hackers, who follow good practices, can remain protected from criminal or civil liability and prosecution.



■ 2

The NIS2 designates the national CSIRT as a coordinator between the vendor and ethical hacker, to ensure safe and timely disclosure of new vulnerabilities.

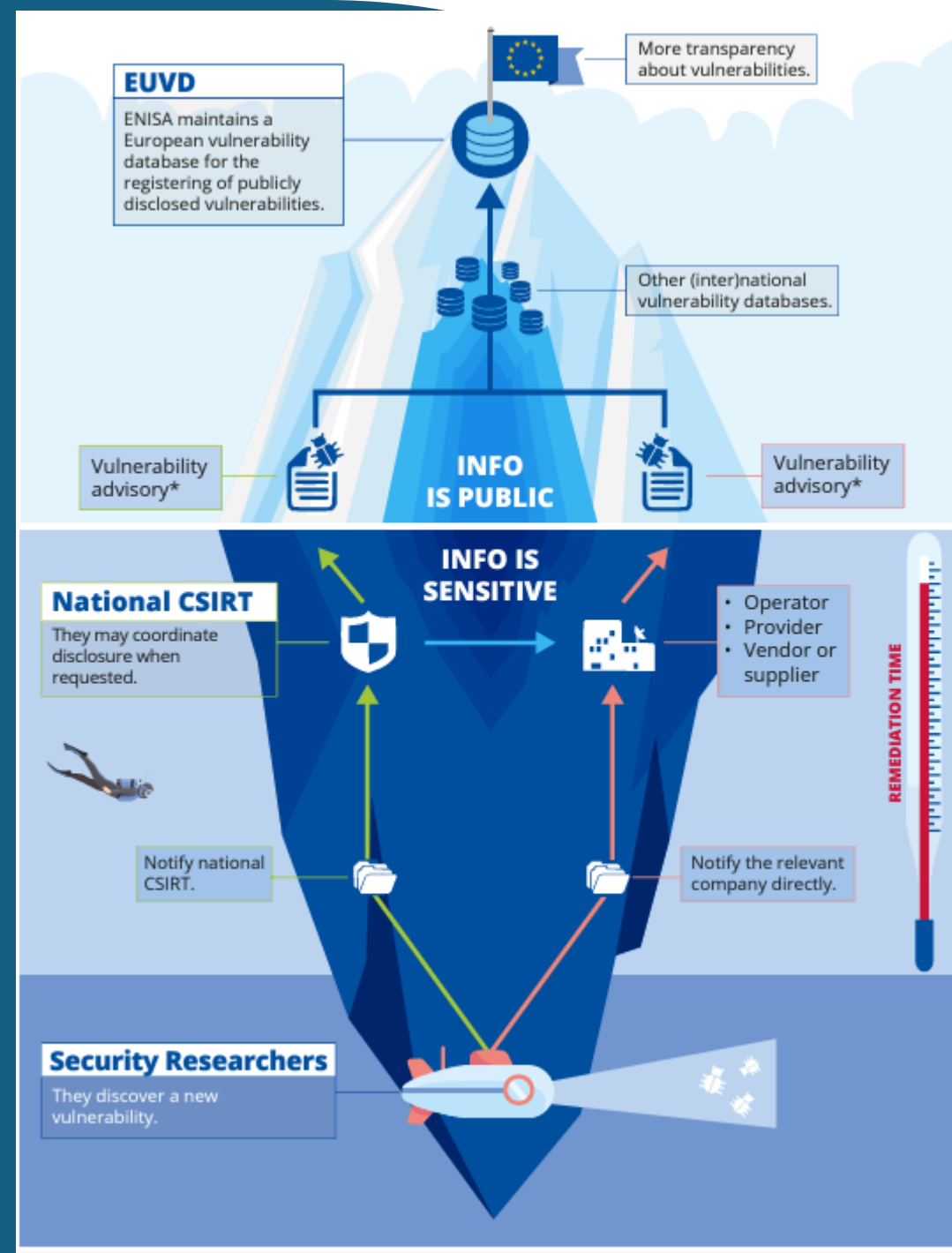


■ 3

For Member States it is important to raise awareness and promote their national CVD policy.



Source: ENISA



NIS 2 Directive

Source: ENISA –
example security measure

3.5 INCIDENT RESPONSE

3.5.1. The relevant entities shall respond to incidents in accordance with documented procedures and in a timely manner.

GUIDANCE

- Establish a dedicated incident response team comprising employees with the necessary technical expertise and authority to respond effectively to incidents.
- Define roles and responsibilities within the incident response team, including incident coordinators, analysts, and communication liaisons.
- Take into account well known standards when developing the incident response procedures¹⁹.

EXAMPLES OF EVIDENCES

- Assignments of roles within the incident response team.
- Documented standards and/or good practices which are taken into account.

3.5.2. The incident response procedures shall include the following stages:

- (a) incident containment, to prevent the consequences of the incident from spreading;
- (b) eradication, to prevent the incident from continuing or reappearing,
- (c) recovery from the incident, where necessary.

GUIDANCE

- Create detailed incident response procedures outlining the steps referred to in point 3.5.2 of the Annex to the Regulation.
- Ensure that the handling of cybersecurity incidents takes into account the entity's priorities and the impact of the incident.
 - Conflicting objectives between:
 - 1) forensic activities to secure evidence,
 - 2) incident response activities to remove existing threats, and
 - 3) objectives of operational IT operations to minimise the impact of the incident,are considered and presented to the management bodies for a decision on how to proceed.

EXAMPLES OF EVIDENCES

- Procedures for incident response, including, types of incidents that could occur, objectives, roles and responsibilities, detailed description, per incident type, how to manage the incident, when to escalate to management bodies (CISO e.g.), etc.
- Records from conflicting objectives resolution during past incidents response.

NIS 2 Directive

3.5.3. The relevant entities shall establish communication plans and procedures:

- (a) with the Computer Security Incident Response Teams (CSIRTs) or, where applicable, the competent authorities, related to incident notification;
- (b) with relevant internal and external stakeholders.

GUIDANCE

- Ensure that the communication plan (3.1.2) includes procedures on how to communicate the incident to relevant authorities and the national CSIRT as well as with the internal and external stakeholders.
- Include contact information for key personnel, external stakeholders, and relevant authorities.

EXAMPLES OF EVIDENCES

- Procedures on how to communicate the incident to relevant authorities and the CSIRT are in place.
- Procedures on how to communicate the incident to customers or how and when to involve a supplier (if applicable).

3.5.4. The relevant entities shall log incident response activities in accordance with the procedures referred to in point 3.2.1., and record evidence.

GUIDANCE

- Log incident response information which at minimum contains (indicative, non-exhaustive list):
 - time of detection, containment and eradication;
 - when the systems recovered;
 - indicators of compromise (IoCs);
 - root cause;
 - actions taken during each phase namely, detection, containment and eradication;
 - impact assessment;
 - communications when responding to the incident;
 - post incident lessons learnt and recommendations; and
 - whether the incident was notified to the CSIRT or the competent authority according to NIS2 articles 23 and 30;

EXAMPLES OF EVIDENCES

- Logs from incident response

Source: ENISA – example security measure

NIS 2 Directive

3.5.5. The relevant entities shall test at planned intervals their incident response procedures.

GUIDANCE

- Test entity's incident response procedures at least annually.
- Test different types of incidents e.g. ransomware, phishing, data breach, DoS, etc.
- Ensure that test scenarios involve employees from different departments as well as external stakeholders e.g. suppliers and service providers.
- Include management bodies in the tests so that they understand their role during an incident.
- Conduct post-test reviews for possible lessons learnt.
- Update the incident response procedures based on the lessons learnt from the test, if applicable.

EXAMPLES OF EVIDENCES

- Documented plans or schedules for future incident response tests.
- Records from tests of different types of incidents.

TIPS

GUIDANCE

- Instructions on how to respond to the most common types of incidents (e.g. ransomware, phishing, data breach, DoS, etc.) including containment, eradication, and recovery steps.
- Include guidelines for preserving evidence and maintaining chain of custody to support forensic analysis and legal proceedings if necessary.
- Consider the use of automated solutions for incident response, e.g. SOAR technologies or similar systems.

EXAMPLES OF EVIDENCES

- Up to date incident response procedures based on test conducted and/or change logs.

Source: ENISA – example security measure

NIS 2 Directive

MAPPING TO STANDARDS & FRAMEWORKS			
European and international frameworks		National Frameworks	
ISO 27001:2022	A.5.26	BE-CyFun®2023	BASIC: RS.RP-1.1
			IMPORTANT: PR.IP-9.1
			ESSENTIAL: PR.IP-9.2, RS.CO-2.2
NIST CSF v2.0	RS.MA-01, RS.MA-02, RS.MA-03, RS.MA-04, ID.IM-02, ID.IM-03, ID.IM-04, RS.CO-02, RS.CO-03, RS.AN-03, RS.MI-01, RS.MI-02, RC.CO-03, RC.CO-04.	FI-Kybermittari	RESPONSE-2, RESPONSE-3
ETSI EN 319 401	REQ-7.9-05, REQ-7.9-09, REQ-7.9-12	EL – Ministerial decision 1027/2019 - Article 4 - paragraph 18	Cybersecurity Handbook: Part B: 17.2, 17.3, 17.4, 17.5, 17.6, 17.9, 17.10
			Self-assessment tool: 18.2, 18.3, 18.4, 18.5, 18.6, 18.7, 18.8
CEN/TS 18026:2024	OIS-03, IM-01, IM-05, IM-07, INQ-02, INQ-03	ES-Royal Decree 311/2022	Article 32, Article 33, Annex II: 4.3.7

Source: ENISA – example security measure

NIS 2 Directive

11.6 AUTHENTICATION

11.6.1. The relevant entities shall implement secure authentication procedures and technologies based on access restrictions and the policy on access control.

GUIDANCE

- Authentication technologies are methods used to verify the identity of users, devices, or systems before granting access to resources. Here are some common authentication technologies (indicative, non-exhaustive list):
 - Password-Based Authentication.
 - Two-Factor Authentication (2FA).
 - Multi-Factor Authentication (MFA).
 - Biometric Authentication.
 - Token-Based Authentication, e.g one-time passcode (OTP).
 - Certificate-Based Authentication.
 - Single Sign-On (SSO).
 - OAuth: An open standard for access delegation, commonly used for token-based authentication and authorization.

EXAMPLES OF EVIDENCES

- Access control policy documents outlining secure authentication procedures and technologies.
- Logs from authentication systems showing successful and failed authentication attempts, which demonstrate secure implementation.
- Evidence of the systems in place that enforce access controls, such as Identity and Access Management (IAM) solutions.
- Internal or external audit reports verifying the implementation of secure authentication procedures aligned with the access control policy.

NIS 2 Directive

11.6.2. For that purpose, the relevant entities shall:

- (a) ensure the strength of authentication is appropriate to the classification of the asset to be accessed;
- (b) control the allocation to users and management of secret authentication information by a process that ensures the confidentiality of the information, including advising personnel on appropriate handling of authentication information;
- (c) require the change of authentication credentials initially, at predefined intervals and upon suspicion that the credentials were compromised;
- (d) require the reset of authentication credentials and the blocking of users after a predefined number of unsuccessful log-in attempts;
- (e) terminate inactive sessions after a predefined period of inactivity; and
- (f) require separate credentials to access privileged access or administrative accounts.

GUIDANCE

- Use unique authentication credentials for all entity's assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.
- Consider that the allocation and management process of authentication information should ensure that:
 - passwords or PINs generated automatically during enrolment processes as temporary secret authentication information are non-guessable and unique for each user; and that users are required to change them after the first use;
 - procedures are established to verify the identity of a user prior to providing new, replacement or temporary authentication information;
 - authentication information, including temporary authentication information, is transmitted to users in a secure manner (e.g. over an authenticated and protected channel); the use of unprotected (clear text) electronic mail messages is avoided;
 - users acknowledge receipt of authentication information;
 - default authentication information as predefined or provided by suppliers is changed immediately following installation of systems or software;
 - records of significant events concerning allocation and management of authentication information are kept and their confidentiality granted; and that the record -keeping method is approved (e.g. using an approved password vault tool).
- When passwords are used as authentication information, the password management system should:
 - allow users to select and change their own passwords and include a confirmation procedure to address input errors;
 - enforce strong passwords
 - force users to change their passwords at first login;

Source: ENISA –
example security measure

NIS 2 Directive

- enforce password changes as necessary, for example after a security incident, or upon termination or change of employment when a user has known passwords for identities that remain active (e.g. shared identities);
- prevent re-use of previous passwords;
- prevent the use of commonly -used passwords and compromised usernames, password combinations from hacked systems;
- not display passwords on the screen when being entered; and
- store and transmit passwords in protected form.
- Perform password encryption and hashing according to approved cryptographic techniques for passwords.
- Generate an alert when a potential attempted or successful breach of log-on controls is detected.

EXAMPLES OF EVIDENCES

- Logs or reports related to authentication.
- Compliance audits from internal or external audits that verify the management of identities aligns with the policy and regulatory requirements.
- Documentation showing that the identities are reviewed regularly and updated as necessary.
- Records of changes to identities, reflecting any alterations due to role changes or termination of employment.

Source: ENISA – example security measure

NIS 2 Directive

11.6.3. The relevant entities shall to the extent feasible use state-of-the-art authentication methods, in accordance with the associated assessed risk and the classification of the asset to be accessed, and unique authentication information.

GUIDANCE

- Adjust authentication methods based on associated assessed risk. For example, require additional authentication for high-risk transactions or access to assets of higher criticality.
- Use more stringent authentication methods for assets of higher criticality.
- Ensure each user has unique credentials. Avoid shared accounts and implement strict policies for credential management.

EXAMPLES OF EVIDENCES

- Access control policy documents outlining secure authentication procedures and technologies.

11.6.4. The relevant entities shall regularly review the authentication procedures and technologies at planned intervals.

GUIDANCE

- Conduct periodic audits of authentication procedures and technologies to ensure they remain state-of-the-art and effective against emerging threats.
- Stay updated on advancements in authentication technology and integrate new methods as they become available.

EXAMPLES OF EVIDENCES

- Internal or external audit reports detailing the results of periodic audits on authentication procedures and technologies.
- Logs showing the implementation of new authentication technologies and methods as they become available

Source: ENISA – example security measure

NIS 2 Directive

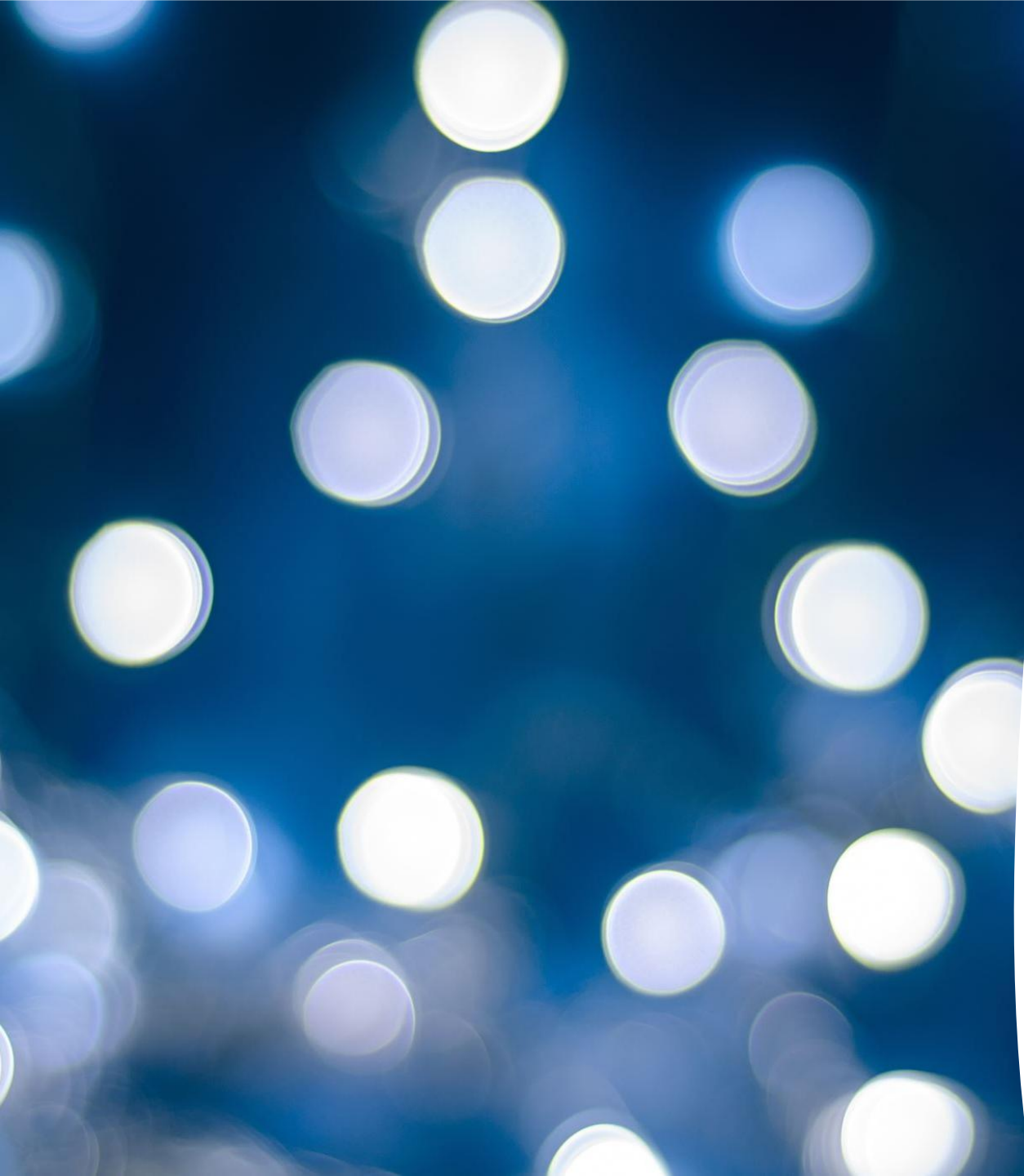
TIPS
GUIDANCE
• Advise any user with access to or using authentication information for the following: ◦ secret authentication information such as passwords are kept confidential. Personal secret authentication information is not to be shared with anyone. Secret authentication information used in the context of identities linked to multiple users or linked to non-personal entities are solely shared with authorized persons; ◦ affected or compromised authentication information is changed immediately upon notification of or any other indication of a compromise; ◦ when passwords are used as authentication information, strong passwords according to best practices recommendations are selected, for example: passwords are not based on anything somebody else can easily guess or obtain using person-related information (e.g. names, telephone numbers and dates of birth); passwords are not based on dictionary words or combinations thereof; use easy to remember passphrases and try to include alphanumeric and special characters; passwords have a minimum length; ◦ the same credentials are not used across distinct network and information systems; and ◦ the obligation to follow these rules are also included in terms and conditions of employment.
EXAMPLES OF EVIDENCES
• Documentation of training sessions for employees on secure authentication practices and technologies. • Records of awareness programs or communications to employees about the importance of secure authentication.

Source: ENISA – example security measure

NIS 2 Directive

MAPPING TO STANDARDS & FRAMEWORKS			
European and international frameworks		National Frameworks	
ISO 27001:2022	A.5.17	BE-CyFun®2023	BASIC: PR.AC-3.2
			IMPORTANT: PR.AC-1.2, PR.AC-1.4, PR.MA-2.2
			ESSENTIAL: PR.AC-6.2
NISTCSF v2.0	PR.AA-05, PR.AA-03, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04	FI-Kybermittari	ACCESS-1, ACCESS-2, ACCESS-3, ACCESS-4, ARCHITECTURE-2, ARCHITECTURE-3, ARCHITECTURE-5
ETSI EN 319 401	REQ-7.4-08	EL – Ministerial decision 1027/2019 - Article 4 - paragraph 8	Cybersecurity Handbook: Part B: 5.1, 5.2, 5.3, 5.4, 5.5, 5.8, 5.10
			Self-assessment tool: 6.1, 6.2, 6.6, 6.7, 6.8, 6.10
CEN/TS 18026:2024	IAM-07, IAM-08	ES-Royal Decree 311/2022	Article 20, Annex II: 4.2.1, 4.2.2, 4.2.3, 4.2.4, 4.2.5, 4.2.6

Source: ENISA – example security measure



Artificial Intelligence Act

The new legal requirements:

- address risks specifically created by AI applications
- prohibit AI practices that pose unacceptable risks
- determine a list of high-risk applications
- set clear requirements for AI systems for high-risk applications
- define specific obligations deployers and providers of high-risk AI applications
- require a conformity assessment before a given AI system is put into service or placed on the market
- put enforcement in place after a given AI system is placed into the market
- establish a governance structure at European and national level

Artificial Intelligence Act

FOCUS AREAS	AI ACT				
ORGANIZATIONS WITHIN SCOPE	Applies to: → Providers, importers and distributors of AI systems or general-purpose AI models that are placed on the EU market, put into service or used in the EU, even if they were established in a third country.				
DEFINITION OF AN AI SYSTEM	A machine-based system designed to operate with varying levels of autonomy that may exhibit adaptiveness after deployment and that, for explicit or implicit objectives, infers from the input it receives, how to generate outputs such as predictions, content, recommendations or decisions that can influence physical or virtual environments.				
RISK LEVELS/ CATEGORIES	Prohibited AI practices	High-risk AI system	General-purpose AI models	General-purpose AI models with systemic risks	Transparency requirements
	A limited set of particularly harmful uses of AI that contravene EU values because they violate fundamental rights. These include: → Social behavioral scoring systems. → Emotion-recognition systems at work and in education. → AI used to exploit people's vulnerabilities, such as their ages or disabilities. → Behavioural manipulation and circumvention of free will. → Untargeted scraping of facial images for facial recognition. → Biometric categorization systems that use certain sensitive characteristics. → Specific predictive policing applications. → Law enforcement use of real-time biometric identification in public, apart from in limited, authorized situations.	AI systems that pose a significant risk to health, safety or fundamental rights, including in the following categories: → Profiling. → Medical devices. → Vehicles. → Emotion-recognition systems. → Law enforcement. → Credit scoring AI systems that are used as a safety component of a product, or are a product themselves, and are regulated by relevant EU sectoral product safety laws.	AI models that display significant generality, are capable of competently performing a wide range of distinct tasks, regardless of how they are placed on the market, and can be integrated into a variety of downstream systems or applications.	General-purpose AI models that have "high-impact capabilities" that match or exceed the capabilities recorded in the most advanced general-purpose AI models. These models must either: → Have high-impact capabilities evaluated against appropriate technical tools, indicators and benchmarks. This is presumed where the cumulative amount of compute used for training is greater than 10^{25} floating point operations. → Be designated as general-purpose AI with systemic risks by the Commission or scientific panel.	Specific transparency obligations are imposed on providers and deployers of certain AI systems. An AI system may be subject to both the transparency requirements and the requirements for high-risk AI systems or general-purpose AI models.

Artificial Intelligence Act

	Prohibited AI practices	High-risk AI system	General-purpose AI models	General-purpose AI models with systemic risks	Transparency requirements
KEY REQUIREMENTS	Such AI systems are prohibited under the AI Act.	These systems require providers to ensure: → Risk management → Data quality and governance. → Documentation and traceability. → Transparency. → Human oversight. → Accuracy, cybersecurity and robustness. → Demonstrated compliance via conformity assessments. → If deployed by public authorities, registration in a public EU database, unless used for law enforcement or migration.	Require providers to: → Perform FRIAs and conformity assessments. → Implement risk management and quality management systems to continually assess and mitigate systemic risks. → Inform individuals when they interact with AI. AI content must be labelled and detectable. → Test and monitor for accuracy, robustness and cybersecurity. General-purpose AI models with systemic risk are subject to greater testing and reporting requirements.	Specific obligations for general-purpose AI models with systemic risks include: → Standardized model evaluation and adversarial testing. → Assessment and mitigation of possible systemic risks. → Documentation of serious incidents and corrective measures. → Adequate level of cybersecurity and physical infrastructure of general-purpose AI models with systemic risks. → Adherence to codes of practice. → Compliance with confidentiality requirements laid under Article 78 for any obtained information or documentation, as well as trade secrets.	Providers of AI systems that interact directly with natural persons must design and develop AI systems to guarantee individual users are aware they are interacting with an AI system. Providers of AI systems that generate synthetic audio, image, video or text content and general-purpose AI systems must ensure outputs are marked in a machine-readable format and detectable as AI generated or manipulated. Deployers of emotion recognition or biometric categorization systems must inform natural persons of the systems' operations. Deployers of AI systems that produce deepfakes or manipulate text meant to inform the public on matters of public interest must abide by disclosure requirements.

Artificial Intelligence Act

SIGNIFICANT PROVISIONS	Transparency. Requirements are imposed on certain AI systems, for example when there is a clear risk of manipulation such as via the use of chatbots. Users should be aware that they are interacting with a machine. Conformity assessments. For AI systems that are safety components of products or are products themselves under listed EU product safety laws, conformity assessments must be performed prior to the systems' placement EU market or when a high-risk AI system is substantially modified. Importers of AI systems must ensure the foreign provider has already carried out the appropriate conformity assessment procedure. FRIAs. Before deployment, public law entity deployers, private operators who provide a public service and private operators who deploy AI systems to evaluate creditworthiness, emergency calls, or risk and pricing for life and health insurance must assess the systems' impact on fundamental rights. If a data protection impact assessment is required, the FRIA should be conducted in conjunction with that DPIA. Generative AI. Providers that generate synthetic audio, image, video or text content must ensure that content is marked in a machine-readable format and is detectable as artificially generated or manipulated.
ENFORCEMENT AND PENALTIES	The AI Office, housed within the European Commission, will supervise AI systems based on general-purpose models when the model and system are provided by the same provider. It will have the powers of a market surveillance authority. National market surveillance authorities are responsible for the supervision of all other AI systems. The AI Office will work to coordinate governance among member countries and supervise enforcement of rules related to general-purpose AI. Member state authorities will lay down rules on penalties and other enforcement measures, including warnings and nonmonetary measures. Individuals can lodge a complaint of infringement with a national competent authority, which can then launch market surveillance activities. The act does not provide for individual damages. There are penalties for: → Prohibited AI violations, up to 7% of global annual turnover or 35 million euros. → Most other violations, up to 3% of global annual turnover or 15 million euros. → Supplying incorrect information to authorities, up to 1% of global annual turnover or 7.5 million euros. The AI Board will advise on the act's implementation, coordinate between national authorities and issue recommendations and opinions.
FURTHER RULEMAKING	The Commission can issue delegated acts on: → Definitions of an AI system. → Criteria and use cases for high-risk AI. → Thresholds for general-purpose AI models with systemic risk. → Technical documentation requirements for general-purpose AI. → Conformity assessments. → EU declarations of conformity. The AI Office is to draw up codes of practice to cover, but not necessarily limited to, obligations for providers of general-purpose AI models. Codes of practice should be ready nine months after the act enters into force at the latest and should provide at least a three-month period before taking effect.



Additional reading material

- Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive)
 - Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)
 - NIS Cooperation Group documents: <https://digital-strategy.ec.europa.eu/en/policies/nis-cooperation-group>
 - NIST Trustworthy and Responsible AI NIST AI 100-2e2023 Adversarial Machine Learning A Taxonomy and Terminology of Attacks and Mitigations
 - NIST Trustworthy and Responsible AI NIST AI 600-1 Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
 - ENISA, Implementation Guidance on NIS2 security measures
<https://www.enisa.europa.eu/publications/implementation-guidance-on-nis-2-security-measures>
-



DORA (Digital Operational Resilience Act)

About DORA

- Covers a set of industries, including financial services, pension funds,
- 5 Key Pillars:
 - ICT Risk Management
 - Incident Reporting
 - Digital Operational Resilience Testing
 - Management of Third-Party Risk
 - Information Sharing

DORA - Scope

Article 2

Scope

1. Without prejudice to paragraphs 3 and 4, this Regulation applies to the following entities:
 - (a) credit institutions;
 - (b) payment institutions, including payment institutions exempted pursuant to Directive (EU) 2015/2366;
 - (c) account information service providers;
 - (d) electronic money institutions, including electronic money institutions exempted pursuant to Directive 2009/110/EC;
 - (e) investment firms;
 - (f) crypto-asset service providers as authorised under a Regulation of the European Parliament and of the Council on markets in crypto-assets, and amending Regulations (EU) No 1093/2010 and (EU) No 1095/2010 and Directives 2013/36/EU and (EU) 2019/1937 ('the Regulation on markets in crypto-assets') and issuers of asset-referenced tokens;
 - (g) central securities depositories;
 - (h) central counterparties;
 - (i) trading venues;
 - (j) trade repositories;
 - (k) managers of alternative investment funds;
 - (l) management companies;
 - (m) data reporting service providers;
 - (n) insurance and reinsurance undertakings;
 - (o) insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries;
 - (p) institutions for occupational retirement provision;
 - (q) credit rating agencies;
 - (r) administrators of critical benchmarks;
 - (s) crowdfunding service providers;
 - (t) securitisation repositories;
 - (u) ICT third-party service providers.

DORA – Sample definitions

- (5) 'ICT risk' means any reasonably identifiable circumstance in relation to the use of network and information systems which, if materialised, may compromise the security of the network and information systems, of any technology dependent tool or process, of operations and processes, or of the provision of services by producing adverse effects in the digital or physical environment;
 - (8) 'ICT-related incident' means a single event or a series of linked events unplanned by the financial entity that compromises the security of the network and information systems, and have an adverse impact on the availability, authenticity, integrity or confidentiality of data, or on the services provided by the financial entity;
- (17) 'threat-led penetration testing (TLPT)' means a framework that mimics the tactics, techniques and procedures of real-life threat actors perceived as posing a genuine cyber threat, that delivers a controlled, bespoke, intelligence-led (red team) test of the financial entity's critical live production systems;
 - (18) 'ICT third-party risk' means an ICT risk that may arise for a financial entity in relation to its use of ICT services provided by ICT third-party service providers or by subcontractors of the latter, including through outsourcing arrangements;
- (15) 'threat intelligence' means information that has been aggregated, transformed, analysed, interpreted or enriched to provide the necessary context for decision-making and to enable relevant and sufficient understanding in order to mitigate the impact of an ICT-related incident or of a cyber threat, including the technical details of a cyber-attack, those responsible for the attack and their modus operandi and motivations;
 - (16) 'vulnerability' means a weakness, susceptibility or flaw of an asset, system, process or control that can be exploited;

DORA – Role of the management

- Article 5 of DORA – except and some key points
 - Strategy
 - Setting roles and responsibilities
 - Oversee implementation
 - Monitor
 - Ensure proper budget

2. The management body of the financial entity shall define, approve, oversee and be responsible for the implementation of all arrangements related to the ICT risk management framework referred to in Article 6(1).

For the purposes of the first subparagraph, the management body shall:

- (a) bear the ultimate responsibility for managing the financial entity's ICT risk;
- (b) put in place policies that aim to ensure the maintenance of high standards of availability, authenticity, integrity and confidentiality, of data;
- (c) set clear roles and responsibilities for all ICT-related functions and establish appropriate governance arrangements to ensure effective and timely communication, cooperation and coordination among those functions;
- (d) bear the overall responsibility for setting and approving the digital operational resilience strategy as referred to in Article 6(8), including the determination of the appropriate risk tolerance level of ICT risk of the financial entity, as referred to in Article 6(8), point (b);
- (e) approve, oversee and periodically review the implementation of the financial entity's ICT business continuity policy and ICT response and recovery plans, referred to, respectively, in Article 11(1) and (3), which may be adopted as a dedicated specific policy forming an integral part of the financial entity's overall business continuity policy and response and recovery plan;
- (f) approve and periodically review the financial entity's ICT internal audit plans, ICT audits and material modifications to them;
- (g) allocate and periodically review the appropriate budget to fulfil the financial entity's digital operational resilience needs in respect of all types of resources, including relevant ICT security awareness programmes and digital operational resilience training referred to in Article 13(6), and ICT skills for all staff;
- (h) approve and periodically review the financial entity's policy on arrangements regarding the use of ICT services provided by ICT third-party service providers;
- (i) put in place, at corporate level, reporting channels enabling it to be duly informed of the following:
 - (i) arrangements concluded with ICT third-party service providers on the use of ICT services,
 - (ii) any relevant planned material changes regarding the ICT third-party service providers,
 - (iii) the potential impact of such changes on the critical or important functions subject to those arrangements, including a risk analysis summary to assess the impact of those changes, and at least major ICT-related incidents and their impact, as well as response, recovery and corrective measures.

DORA - Outline

- ICT Risk management

The management of a financial entity must define, approve, oversee, and be accountable for the implementation of all aspects concerning ICT risk management framework

Management should link the business strategy to the resilience strategy, with an agreed set of critical business functions and which assets are critical/important for their proper functioning.

- Incident reporting

Entities must establish and implement an ICT-related incident management process to detect, manage, and notify ICT-related incidents and to put in place early warning indicators as alerts

Entities must design a classification framework for incident management, which should be consistent throughout any typology of incident.

DORA - Outline

- Digital Operational Resilience Testing

Entities have to set in place a comprehensive testing program that includes a wide variety of tests limited not just to IT assets, but also on processes and people (to discuss correlation with TIBER).

The exhaustive testing framework should be governed through a risk-based approach, while having in mind service criticality classification of such process or IT asset.

- Management of Third-Party Risk

Entities must manage ICT third-party risk within their ICT risk management process.

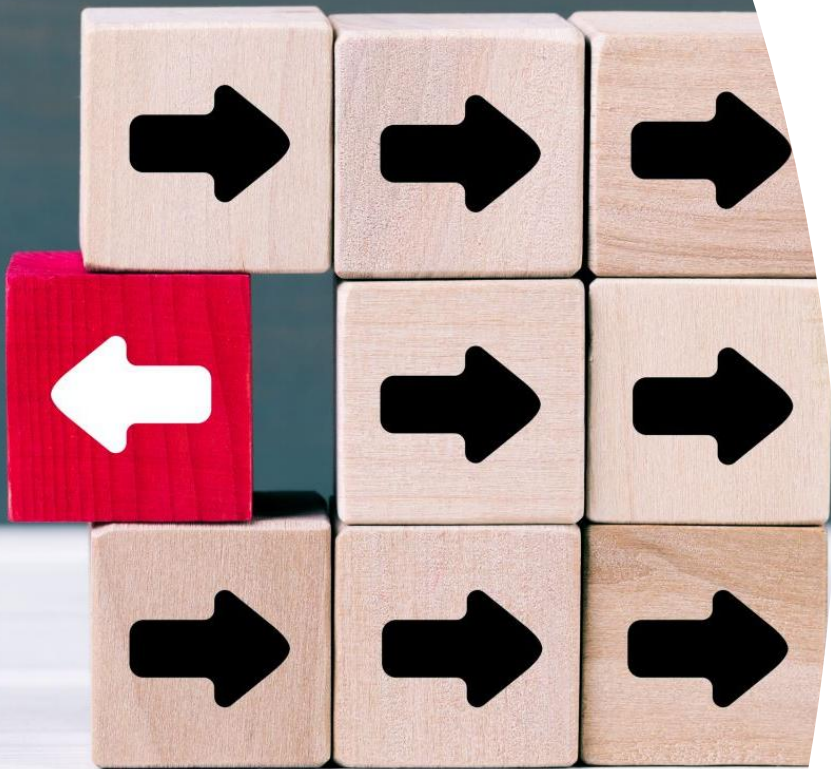
Adequate due diligence of third party providers and proper contractual agreements that clearly set out rights and obligations as per legal requirements.

- Information Sharing

Entities may exchange among themselves cyber threat information and intelligence, including indicators of compromise, tactics, techniques, and procedures, cyber security alerts, and configuration tools.

Concept – critical or important functions

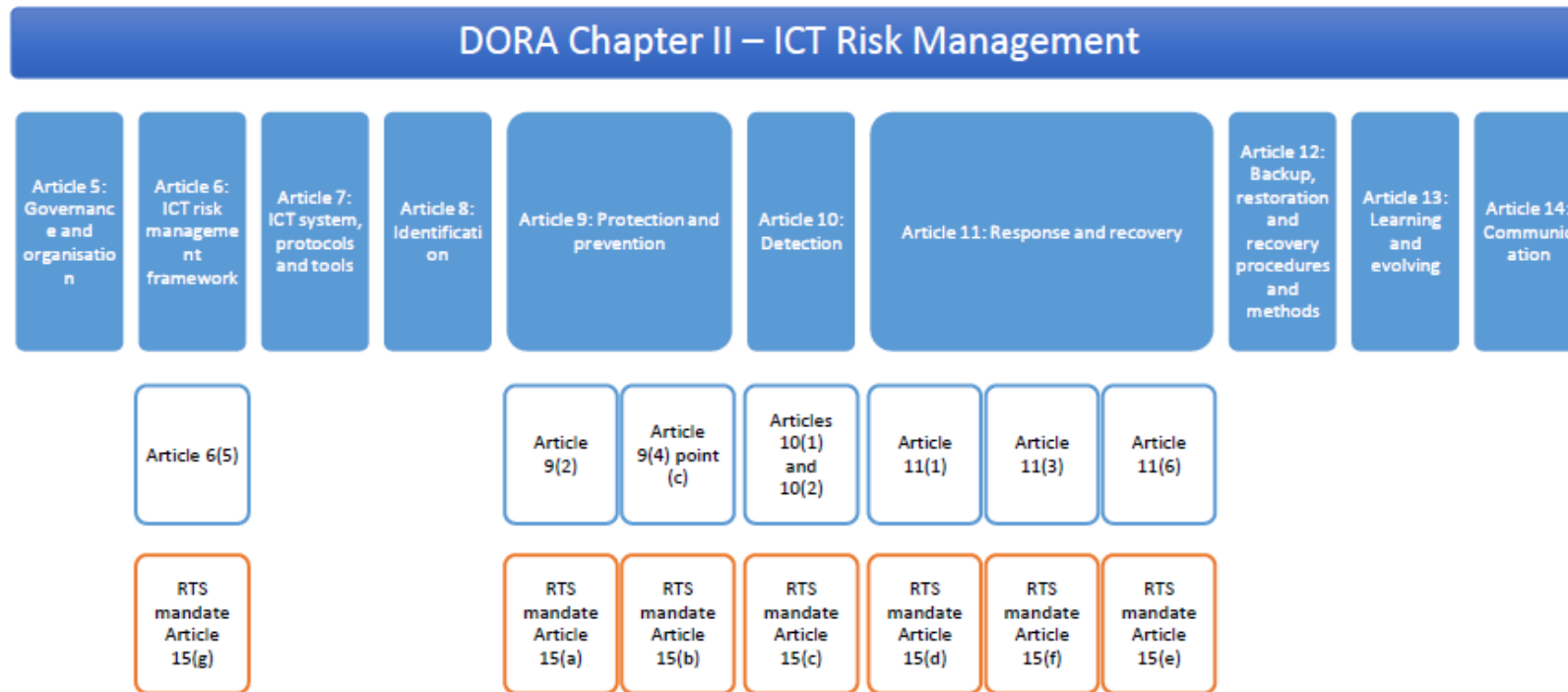
- means a function,
 - the **disruption** of which => would materially impair the **financial performance** of a financial entity,
 - or the soundness or continuity of its services and activities, or the **discontinued, defective or failed performance** of that function => would materially impair the continuing **compliance** of a financial entity with the conditions and obligations of its **authorisation**, or with its other obligations under applicable financial services **law**;



ICT Risk management

- DORA provisions
- RTS provisions

ICT Risk management



ICT Risk management

- Article 3 of the RTS on ICT Risk management

- (a) the indication of the approval of the risk tolerance level for ICT risk established according to Article 6(8), point (b), of Regulation (EU) 2022/2554;
- (b) the procedure and the methodology to conduct the ICT risk assessment, identifying vulnerabilities and threats that affect or may affect the supported business functions, the ICT systems and ICT assets supporting those functions and the quantitative or qualitative indicators to measure impact and likelihood of those vulnerabilities being exploited by threats;
- (c) the procedure to identify, implement and document ICT risk treatment measures for the ICT risk assessed, including the determination of ICT risk treatment measures necessary to bring ICT risk within the risk tolerance levels referred to in point (a). The procedure shall ensure the monitoring of the effectiveness of the measures implemented, the assessment of whether the established risk tolerance levels of the financial entity have been attained and that the financial entity takes actions to correct or improve the measures where necessary;
- (d) with reference to the ICT risk that is still present following the implementation of the ICT risk treatment measures:
 - (i) provisions on the identification of residual ICT risks;
 - (ii) the assignment of roles and responsibilities regarding the acceptance of the residual ICT risks that exceed the financial entity's risk tolerance level referred to in point (a), and for the assessment process referred to in point (iv);
 - (iii) the development of an inventory of the accepted residual ICT risks, including an explanation of the reasons for which they were accepted;
 - (iv) provisions on the assessment of the accepted residual ICT risks at least once a year, including the identification of any changes to the residual ICT risks, the assessment of available mitigation measures and the assessment of whether the reasons justifying the acceptance of residual ICT risks are still valid and applicable at the date of the review;
- (e) provisions on the monitoring of any changes to the ICT risk and cyber threat landscape, internal and external vulnerabilities and threats and of ICT risk of the financial entity to promptly detect changes that could affect its ICT risk profile;

DORA – ICT Risk Management

Certain key points from DORA Article 7

strategy

policy, procedure

ICT risk overseen by a control function (2nd line of defence) - segregation and independence

ICT risk management framework reviewed at least once a year

KPIs (key performance indicators) and KRIs (Key risk indicators)

Article 8 of DORA - Identification

Identify, classify and document ICT business functions and ICT assets and information assets supporting those functions

Identify risk exposure through identification of threats and vulnerabilities

Perform risk assessment after each major change in network and information system infrastructure

Monitor changes in the ICT landscape

Update regularly inventories

Article 9 of DORA - Protection and prevention

security at all levels of the OSI model through policies, implementation of controls and monitoring

vulnerability management

security by design in change management

implement risk-based approach

DORA – ICT Risk Management

Article 10 of DORA - Detection

detection of anomalous activities

sufficient resources and capabilities for
incident response process

lessons learnt process

Article 11 - Response and recovery

ensure continuity of critical or important
functions

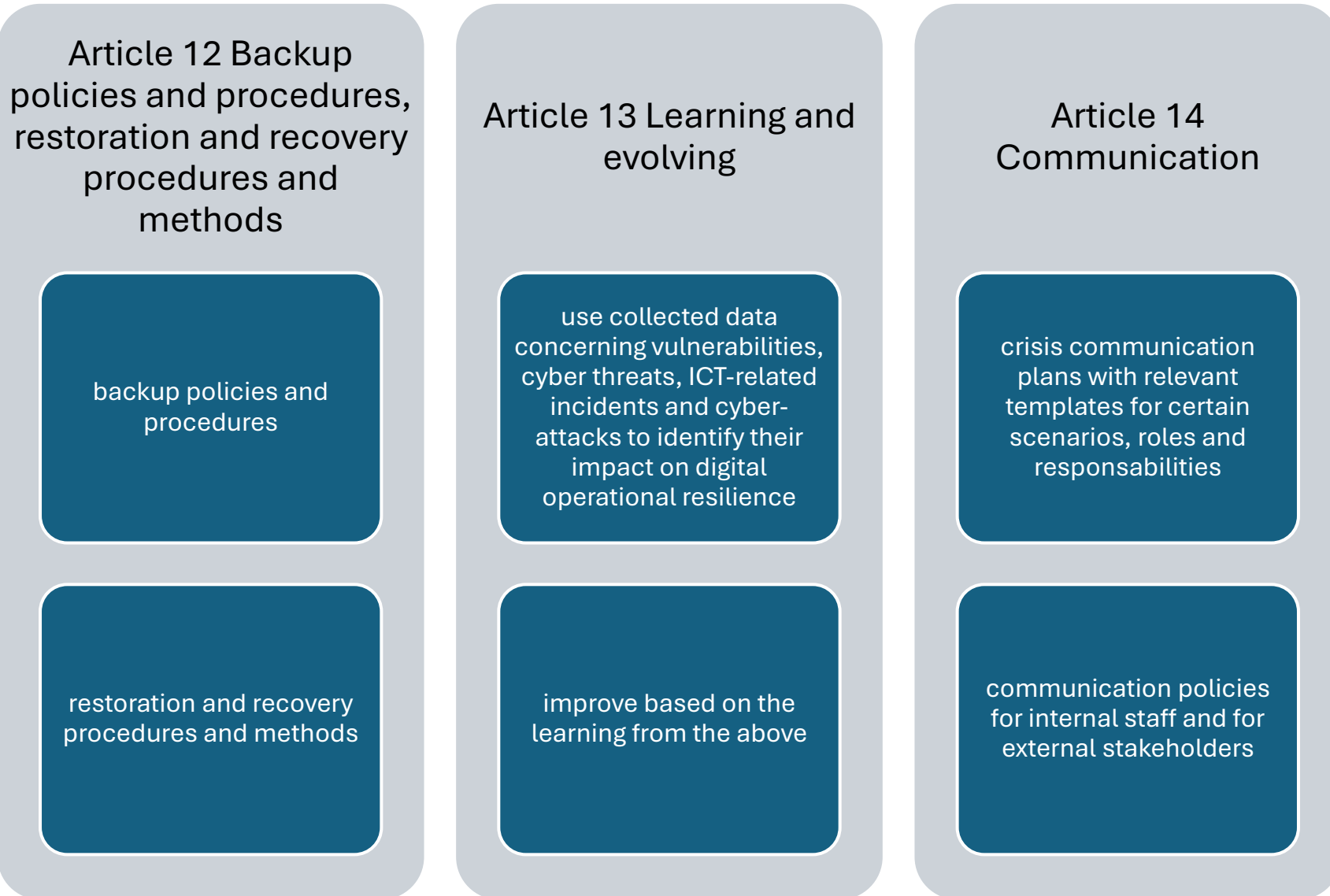
quickly, appropriately and effectively
respond to and resolve ICT related
incidents

estimate impacts, damages, losses

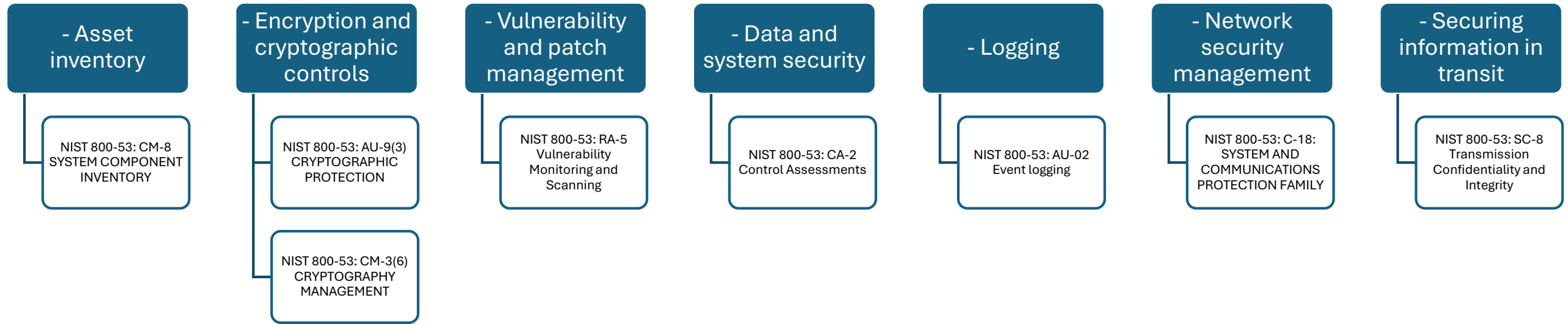
crisis management and communication

test business continuity plans and crisis
communication plans

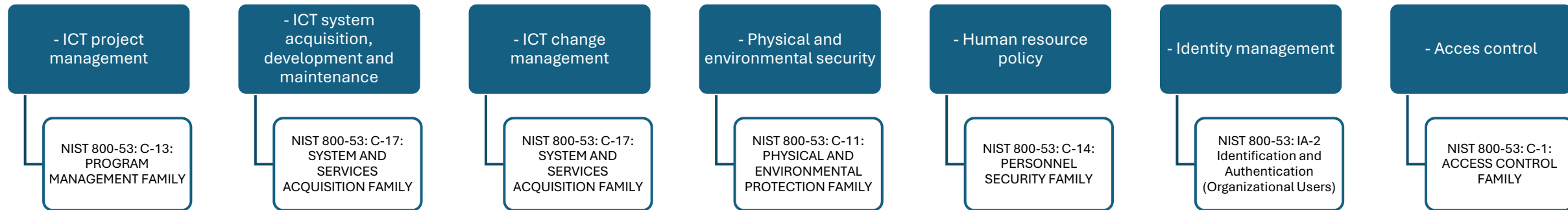
DORA – ICT Risk Management



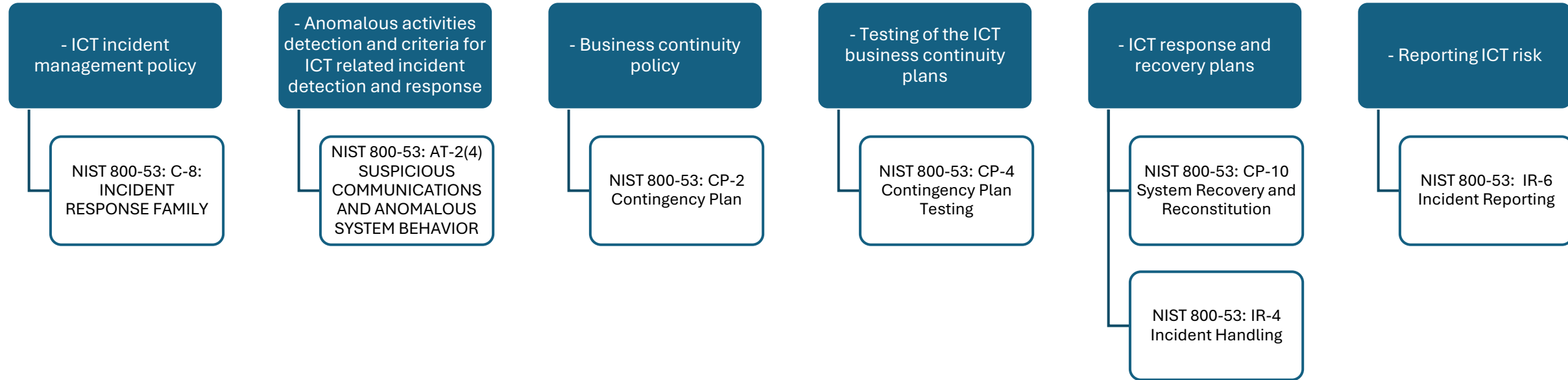
DORA – RTS ICT Risk Management – main areas covered



DORA – RTS ICT Risk Management – main areas covered



DORA – RTS ICT Risk Management – main areas covered



Examples RTS requirements for ICT risk management

Article 8

Policies and procedures for ICT operations

1. As part of the ICT security policies and procedures, financial entities shall develop, document and implement policies and procedures to manage the ICT operations of ICT assets, with a view to ensuring the security of networks, enabling adequate safeguards against intrusions and data misuse and preserving the availability, authenticity, integrity and confidentiality of data. These policies and procedures shall define how financial entities operate, monitor, control and restore their ICT assets, including the documentation of ICT operations.
2. The policies and procedures for ICT operations referred to in paragraph 1 shall include all of the following elements:
 - (a) ICT assets description, including all of the following:
 - (i) secure installation, maintenance, configuration and deinstallation of ICT systems;
 - (ii) management of information assets used by ICT assets, including their processing and handling, automated and manual;
 - (iii) identification and control of legacy ICT systems;
 - (b) controls and monitoring of ICT systems, including all of the following:
 - (i) backup and restoration requirements of ICT systems;
 - (ii) scheduling requirements, taking into consideration interdependencies among the ICT systems;
 - (iii) protocols for audit-trail and system log information;

Examples RTS requirements for ICT risk management

- (iv) requirements to ensure that the performance of internal audit and other testing minimises disruptions to business operations;
 - (v) requirements on the separation of ICT production environments from the development, testing and other non-production environments. The separation shall consider all of the components of the environment, such as accounts, data or connections;
 - (vi) requirements to conduct the development and testing in environments which are separated from the production environment;
 - (vii) requirements to conduct the development and testing in production environments. The policies and procedures shall provide that the instances in which testing is performed in production environment are clearly identified, justified, for limited periods of time approved by the relevant function, and considering Article 16(6). The availability, confidentiality, integrity and authenticity of ICT systems and production data shall be ensured during development and test activities in production environment;
- (c) error handling concerning ICT systems, including all of the following:
- (i) procedures and protocols for handling errors;
 - (ii) support and escalation contacts, including external support contacts in case of unexpected operational or technical issues;
 - (iii) ICT system restart, rollback and recovery procedures for use in the event of ICT system disruption.

DORA – Reporting ICT risk

CHAPTER V

REPORT ON THE ICT RISK MANAGEMENT FRAMEWORK REVIEW

Article 27

Format and content

1. Financial entities shall develop and document the report referred to in Article 6(5) of Regulation (EU) 2022/2554 in a searchable electronic format.
2. Financial entities shall include all of the following information in the report:
 - (a) an introductory section which:
 - (i) clearly identifies the financial entity, the subject of the report and describes its group structure, where relevant;
 - (ii) describes the context of the report in terms of the nature, scale and complexity of the financial entity's services, activities and operations, its organisation, identified critical functions, strategy, major ongoing projects or activities, relationships and its dependence on in-house and contracted ICT services and systems or the implications that a total loss or severe degradation of such systems would have in terms of critical or important functions and market efficiency;
 - (iii) summarises the major changes in the ICT risk management framework since the previous report;
 - (iv) provides an executive level summary of the current and near-term ICT risk profile, threat landscape, the assessed effectiveness of its controls and the security posture of the financial entity;
 - (b) date of the approval of the report by the management body of the financial entity;
 - (c) description of the reason for the review of the ICT risk management framework in accordance with Article 6(5) of Regulation (EU) 2022/2554. Where the review was initiated following supervisory instructions or conclusions derived from relevant digital operational resilience testing or audit processes, the report shall contain explicit references to such documents or instructions, allowing for the identification of the reason for initiating the review. Where the review was initiated following ICT-related incidents, the report shall contain the list of all ICT-related incidents with incident root-cause analysis;
 - (d) start and end dates of the review period;
 - (e) indication of the function responsible for the review;
 - (f) description of the major changes and improvements to the ICT risk management framework since the previous review. This description shall include an analysis of the impact of the changes on the financial entity's digital operational resilience strategy, on the financial entity's ICT internal control framework and on the financial entity's ICT risk management governance;
 - (g) summary of the findings of the review and detailed analysis and assessment of the severity of the weaknesses, deficiencies and gaps in the ICT risk management framework during the review period;
 - (h) description of the measures to address identified weaknesses, deficiencies and gaps, including all of the following:
 - (i) summary of measures taken to remediate to identified weaknesses, deficiencies and gaps;
 - (ii) expected date for implementing the measures and dates related to the internal control of the implementation, including information on the state of progress of their implementation as at the date of drafting of the report, explaining, where applicable, if there is a risk that deadlines may not be respected;
 - (iii) tools to be used and identification of the function responsible for carrying out the measures, detailing whether they are internal or external;
 - (iv) description of the impact of the changes envisaged in the measures on the financial entity's budgetary, human and material resources, including resources dedicated to the implementation of corrective measures;
 - (v) information on the process for informing the competent authority, where appropriate;
 - (vi) if the weaknesses, deficiencies or gaps identified are not subject to remedial measures, a detailed explanation of the criteria used to analyse their impact, to evaluate the related residual risk and for the acceptance of such a risk;
 - (i) information on planned further developments;
 - (j) conclusions resulting from the review of the ICT risk management framework;
 - (k) information on past reviews:
 - (i) list of past reviews to date;
 - (ii) if applicable, state of implementation of the mitigation measures identified by the last report;

DORA – Reporting ICT risk

- Note: Simplified version of ICT risk management framework for certain entities, according to article 16(1) of DORA

(iii) where applicable, description of whether the proposed remedying measures in past reviews have proven ineffective or created unexpected challenges, and how they could be improved;

(l) sources of information used in the preparation of the report, including at least all of the following:

(i) for financial entities referred to in Article 6(6), of Regulation (EU) 2022/2554, results from internal audit;

(ii) results from compliance assessments;

(iii) results from digital operational resilience testing and, where applicable, advanced testing of ICT tools, systems and processes based on TLPT;

(iv) external sources.

- Detect ICT incidents
- Manage ICT incidents
- Notify ICT incidents

ICT-related incidents

3. The ICT-related incident management process referred to in paragraph 1 shall:
 - (a) put in place early warning indicators;
 - (b) establish procedures to identify, track, log, categorise and classify ICT-related incidents according to their priority and severity and according to the criticality of the services impacted, in accordance with the criteria set out in Article 18(1);
 - (c) assign roles and responsibilities that need to be activated for different ICT-related incident types and scenarios;
 - (d) set out plans for communication to staff, external stakeholders and media in accordance with Article 14 and for notification to clients, for internal escalation procedures, including ICT-related customer complaints, as well as for the provision of information to financial entities that act as counterparts, as appropriate;
 - (e) ensure that at least major ICT-related incidents are reported to relevant senior management and inform the management body of at least major ICT-related incidents, explaining the impact, response and additional controls to be established as a result of such ICT-related incidents;
 - (f) establish ICT-related incident response procedures to mitigate impacts and ensure that services become operational and secure in a timely manner.

ICT-related incidents

DORA Regulation

Article 18

Classification of ICT-related incidents and cyber threats

1. Financial entities shall classify ICT-related incidents and shall determine their impact based on the following criteria:
 - (a) the number and/or relevance of clients or financial counterparts affected and, where applicable, the amount or number of transactions affected by the ICT-related incident, and whether the ICT-related incident has caused reputational impact;
 - (b) the duration of the ICT-related incident, including the service downtime;
 - (c) the geographical spread with regard to the areas affected by the ICT-related incident, particularly if it affects more than two Member States;
 - (d) the data losses that the ICT-related incident entails, in relation to availability, authenticity, integrity or confidentiality of data;
 - (e) the criticality of the services affected, including the financial entity's transactions and operations;
 - (f) the economic impact, in particular direct and indirect costs and losses, of the ICT-related incident in both absolute and relative terms.

ICT-related incidents

Draft Regulatory Technical Standards

on the content of the notification and reports for major incidents and significant cyber threats and determining the time limits for reporting major incidents

Table 1: Overview of the classification criteria and their thresholds for major incidents under DORA as introduced in the final draft RTS

Major ICT-related Incident or security or operational payment-related incident							
if critical services are affected and (i) <u>any malicious unauthorised access to network and information systems identified, which may result to data losses</u> or (ii) the thresholds of two additional criteria from the below are met							
	Mandatory condition	Additional classification criteria					
	Critical services affected	Clients, financial counterparts and transactions	Data losses	Reputational Impact	Duration and Service Downtime	Geographical Spread	Economic Impact
Materiality threshold	The incident has had any impact on critical services	Any of: a) >10% of all clients using the affected service; b) >100 000 clients using the affected service; c) >30% of all financial counterparts used by the FE; d) >10% of the daily average number of transactions; e) >10% of the daily average amount of transactions; f) any identified impact on clients or financial counterpart identified by the FE as relevant.	Any impact on the availability, authenticity, integrity or confidentiality of data, which has or will have an adverse impact on the implementation of the business objectives of the FE or on meeting regulatory requirements	Any reputational impact set out in Article 2 a) to d) (overview below)	a) incident duration is longer than 24 hours; or b) service downtime is longer than 2 hours for ICT services that support critical or important functions	Any impact of the incident identified in the territories of at least two Member States	Costs and losses incurred by the FE exceed or are likely to exceed €100 000 (can be based on estimates where actuals cannot be determined)
Criteria Detail	Assess if the incident : a) affects ICT services or Network and information systems that support critical or important functions of the FE; or b) affects financial services that require authorisation, registration or are otherwise supervised by competent authorities; or c) represents a successful, malicious and unauthorised access to the network and information systems of the financial entity.	1. all affected clients unable to make use of the service provided by the FE during the incident or that were adversely impacted by the incident. These include also third parties explicitly covered by the contractual agreement between the FE and the client as beneficiaries of the affected service. 2. all affected financial counterparts with contractual arrangements with the FE. 3. relevant clients and financial counterparts whose impact will affect the business objectives of the FE or market efficiency. 4. all affected transactions with monetary amount, with one leg in the EU. (FEs can use estimates from comparable reference periods where actuals not available)	1. availability of data – data on demand rendered temporarily or permanently inaccessible or unusable; 2. authenticity of data – compromised trustworthiness of the source of data; 3. integrity of data – data inaccurate or incomplete due to non- authorised modification 4. confidentiality of data – data being accessed by or disclosed to unauthorised party or system.	Reputational impact evidenced by any of the below: a) incident reflected in the media; or b) received repetitive complaints; or c) inability to meet regulatory requirements; or d) likely loss of clients or financial counterparts with a material impact on FE's business. Level of visibility of the incident to be taken into account.	1. Duration measured from the moment an incident occurs or is detected, until it is resolved. (estimate if not yet known) 2. Service downtime measured from the moment service fully/ partially unavailable/ delayed to clients, financial counterparts or other internal or external users, until activities are restored to the same level before the incident.	Assess significant impact of the incident in other EU Member States on: a) clients or financial counterparts; b) branches of the FE or other group financial entities; (c) Financial market infrastructures or third party providers that may affect other FEs.	Types of direct and indirect incurred costs a) expropriated funds or financial assets liability, including theft; b) replacement or relocation costs; c) staff costs; d) contract non-compliance fees; e) customer redress and compensation costs; f) forgone revenues; g) communication costs; h) advisory costs. (based on available data at time of reporting)
Triggered Yes/No							

ICT-related incidents

DORA Regulation

Article 19 - Reporting

4. Financial entities shall, within the time limits to be laid down in accordance with Article 20, first paragraph, point (a), point (ii), submit the following to the relevant competent authority:

- (a) an initial notification;
- (b) an intermediate report after the initial notification referred to in point (a), as soon as the status of the original incident has changed significantly or the handling of the major ICT-related incident has changed based on new information available, followed, as appropriate, by updated notifications every time a relevant status update is available, as well as upon a specific request of the competent authority;
- (c) a final report, when the root cause analysis has been completed, regardless of whether mitigation measures have already been implemented, and when the actual impact figures are available to replace estimates.

ICT-related incidents

Draft Regulatory Technical Standards

on the content of the notification and reports for major incidents and significant cyber threats and determining the time limits for reporting major incidents

Article 3 *Content of initial notifications*

Financial entities shall provide at least the following information about the incident in the initial notification:

- a) incident reference code
- b) date and time of detection and classification of the incident;
- c) description of the incident;
- d) classification criteria that triggered the incident report as set out in [Articles 1 to 8 of Delegated Regulation [insert number once published in official journal]];
- e) members States impacted by the incident, where applicable;
- f) information on how the incident has been discovered;
- g) information about the origin of the incident, where available;
- h) indication whether a business continuity plan has been activated;
- i) information about the reclassification of the incident from major to non-major, where applicable; and
- j) other information, where available.

Article 4 *Content of intermediate reports*

Financial entities shall provide at least the following information about the incident in the intermediate report:

- a) incident reference code provided by the competent authority, where applicable;
- b) date and time of occurrence of the incident;
- c) date and time when regular activities have been restored, where applicable;
- d) information about the classification criteria that triggered the incident report;
- e) type of the incident;
- f) threats and techniques used by the threat actor, where applicable;
- g) affected functional areas and business processes;
- h) affected infrastructure components supporting business processes;
- i) impact on the financial interest of clients;
- j) information about reporting to other authorities;
- k) temporary actions/measures taken or planned to be taken to recover from the incident; and
- l) information on indicators of compromise, where applicable.

Article 5 *Content of final reports*

Financial entities shall provide the following information about the incident in the final report:

- a) information about the root causes of the incident
- b) dates and times when the incident was resolved and the root cause addressed;
- c) information on the incident resolution;
- d) information relevant for resolution authorities, where applicable;
- e) information about direct and indirect costs and losses stemming from the incident and information about financial recoveries; and
- f) information about recurring incidents, where applicable.

Digital operational resilience testing

DORA Regulation

Article 25

Testing of ICT tools and systems

1. The digital operational resilience testing programme referred to in Article 24 shall provide, in accordance with the criteria set out in Article 4(2), for the execution of appropriate tests, such as vulnerability assessments and scans, open source analyses, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, source code reviews where feasible, scenario-based tests, compatibility testing, performance testing, end-to-end testing and penetration testing.

8. Financial entities shall contract testers for the purposes of undertaking TLPT in accordance with Article 27. When financial entities use internal testers for the purposes of undertaking TLPT, they shall contract external testers every three tests.

Article 27

Requirements for testers for the carrying out of TLPT

1. Financial entities shall only use testers for the carrying out of TLPT, that:
 - (a) are of the highest suitability and reputability;
 - (b) possess technical and organisational capabilities and demonstrate specific expertise in threat intelligence, penetration testing and red team testing;
 - (c) are certified by an accreditation body in a Member State or adhere to formal codes of conduct or ethical frameworks;
 - (d) provide an independent assurance, or an audit report, in relation to the sound management of risks associated with the carrying out of TLPT, including the due protection of the financial entity's confidential information and redress for the business risks of the financial entity;
 - (e) are duly and fully covered by relevant professional indemnity insurances, including against risks of misconduct and negligence.
2. When using internal testers, financial entities shall ensure that, in addition to the requirements in paragraph 1, the following conditions are met:
 - (a) such use has been approved by the relevant competent authority or by the single public authority designated in accordance with Article 26(9) and (10);
 - (b) the relevant competent authority has verified that the financial entity has sufficient dedicated resources and ensured that conflicts of interest are avoided throughout the design and execution phases of the test; and
 - (c) the threat intelligence provider is external to the financial entity.

Digital operational resilience testing

40. The main stakeholders in a TLPT are:

- The **TLPT cyber team** (or TCT) mirrors the TIBER cyber team in the TIBER-EU framework. It is the staff within the TLPT authority where all operative TLPT-related matters are addressed. For example, it may be comprised of the test managers;
- The **control team** mirrors the white team under the TIBER-EU framework and manages the TLPT from the side of the financial entity undergoing the exercise. This includes all aspects from procurement of the external providers, the risk assessment the operational management of the day-to-day testing activities, risk management, etc. The control team lead should have the necessary mandate within the financial entity to guide all the aspects of the test, without compromising the secrecy of the test;
- The **blue team** is, similarly to the TIBER-EU framework, made up of those employees that are defending the financial entity against simulated or real cyber threat while not knowing that they are tested;
- The **threat intelligence provider**, similar to the TIBER-EU framework concept, mimics an hacker information gathering activity by using multiple reliable sources;
- DORA concept of '**testers**' is broader than that of 'red team' under the TIBER-EU framework as DORA permits the use of both internal and external testers. Tested entities may use both types of testers as long as all requirements are complied with. Part of the ESA's mandate was to develop specific requirements applying to the use of internal testers (please see section 3.6 below).

Article 26

11

Scope of TLPT: several or all critical or important functions - production environment

3rd parties: if services/applications provided by third parties are in scope, the 3rd parties should participate

Reporting to DORA authority: summary of findings and remediation plans

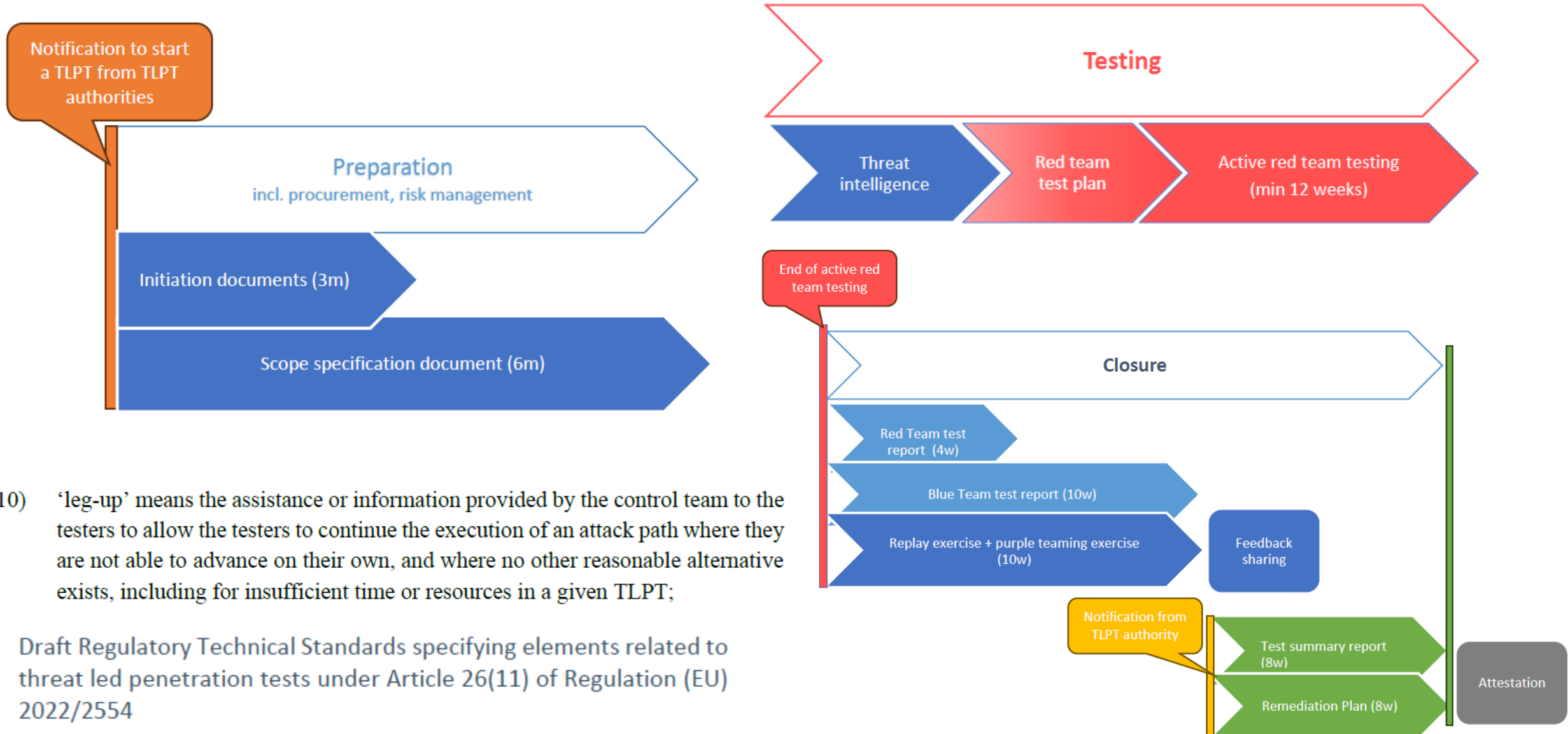
(i) testers and the threat intelligence provider are prohibited from the following activities:

- i. unauthorised destruction of equipment of the financial entity and of its ICT third-party service providers, if any;
- ii. uncontrolled modification of information and ICT assets of the financial entity and of its ICT third-party service providers, if any;
- iii. intentionally compromising the continuity of critical or important functions of the financial entity;
- iv. unauthorised inclusion of out-of-scope systems;
- v. unauthorised disclosure of test results.

7. During the entire active red team testing phase, testers shall report at least weekly to the control team and test managers on the progress made in the TLPT, and the threat intelligence provider shall remain available for consultation and additional threat intelligence when requested by the control team.
8. The control team shall timely provide leg-ups designed on the basis of the red team test plan. Leg-ups may be added or adapted upon approval by the control team and the test managers.
9. In case of detection of the testing activities by any staff member of the financial entity or of its ICT third-party service providers or ICT intragroup service provider, where relevant, the control team, in consultation with the testers and without prejudice to paragraph 10, shall propose and submit measures allowing to continue the TLPT while ensuring its secrecy to the test managers for validation.

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

Digital operational resilience testing



(10) ‘leg-up’ means the assistance or information provided by the control team to the testers to allow the testers to continue the execution of an attack path where they are not able to advance on their own, and where no other reasonable alternative exists, including for insufficient time or resources in a given TLPT;

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

Digital operational resilience testing

ANNEX III

Content of the targeted threat intelligence report

The targeted threat intelligence report shall include information on all of the following:

1. Overall scope of the intelligence research including at least the following:
 - a. critical or important functions in scope;
 - b. their geographical location;
 - c. official EU language in use;
 - d. relevant ICT third party services providers;
 - e. period of time over which the research is gathered.
2. Overall assessment of what concrete actionable intelligence can be found about the financial entity, such as:
 - a. employee usernames and passwords;
 - b. look-alike domains which can be mistaken for official domains of the financial entity;
 - c. technical reconnaissance: vulnerable and/or exploitable software, systems and technologies;
 - d. information posted by employees on social media, related to the financial entity, which might be used for the purposes of an attack;
 - e. information for sale on the dark web;
 - f. any other relevant information available on the internet or public networks;
 - g. where relevant, physical targeting information, including ways of access to the premises of the financial entity.
3. Threat intelligence analysis considering the general threat landscape and the particular situation of the financial entity, including, at least:
 - a. Geopolitical environment;
 - b. Economic environment;

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

- c. Technological trends and any other trends related to the activities in the financial services sector;
4. Threat profiles of the malicious actors (specific individual/group or generic class) that may target the financial entity, including the systems of the financial entity that malicious actors are most likely to compromise or target, the possible motivation, intent and rationale for the potential targeting and the possible modus operandi of the attackers.
5. Threat scenarios: At least three end-to-end threat scenarios for the threat profiles identified in accordance with point 4 who exhibit the highest threat severity scores. The threat scenarios shall describe the end-to-end attack path and shall include, at least:
 - a. one scenario that includes but is not limited to compromised service availability;
 - b. one scenario that includes but is not limited to compromised data integrity;
 - c. one scenario that includes but is not limited to compromised information confidentiality.
6. Where relevant, description of the scenario referred to in Article 7(4).

Digital operational resilience testing

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

ANNEX IV

Content of the red team test plan

The red team test plan shall include information on all of the following:

- (i) communication channels and procedures;
- (ii) the tactics, techniques and procedures allowed and not-allowed for use in the attack including ethical boundaries for social engineering, and how the privacy of involved parties is being safeguarded;
- (iii) risk management measures to be followed by the testers;
- (iv) a description for each scenario, including:
 - a. the simulated threat actor;
 - b. their intent, motivation and goals;
 - c. the target function(s) and the supporting ICT system or systems;
 - d. the targeted confidentiality, integrity, availability and authenticity aspects;
 - e. flags;
- (v) a detailed description of each expected attack path, including pre-requisites and possible leg-ups to be provided by the control team, including deadlines for their provision and potential usage;
- (vi) scheduling of red teaming activities, including time planning for the execution of each scenario, at a minimum split according to the three phases a tester takes throughout the testing phase, respectively entering financial entities' ICT systems, moving through the ICT systems and ultimately executing actions on objectives and eventually extracting itself from the ICT systems (in, through and out phases);
- (vii) particularities of the financial entities' infrastructure to be considered during testing;
- (viii) if any, additional information or other resources necessary to the testers for executing the scenarios.

ANNEX V

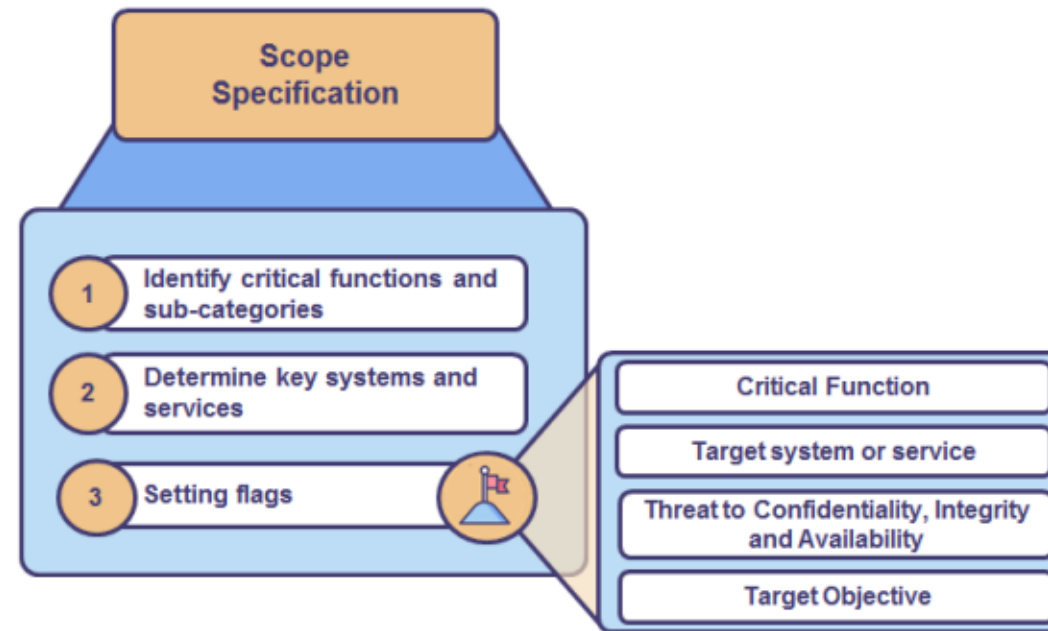
Content of the red team test report

The red team test report shall include information on at least all of the following:

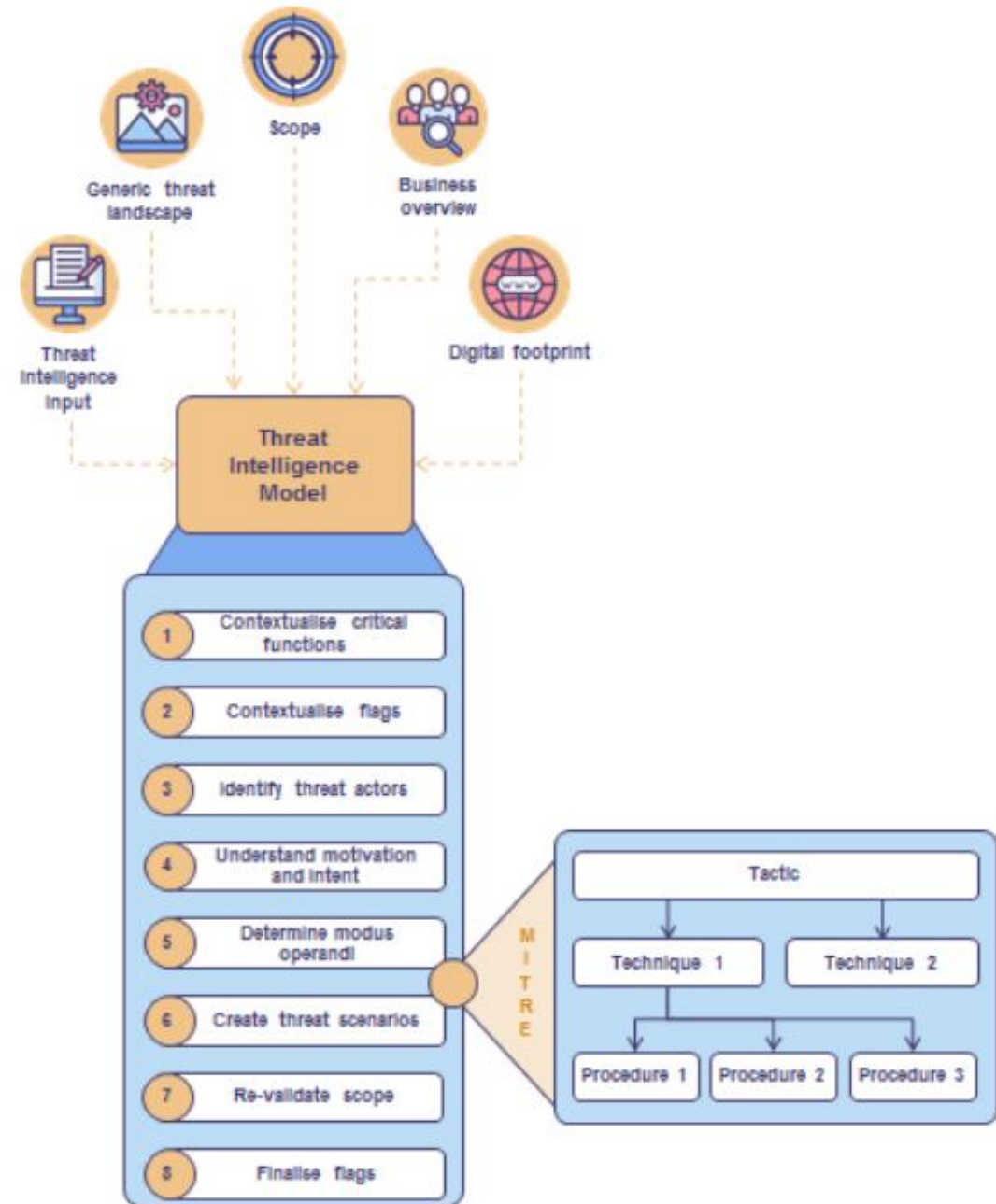
- (a) Information on the performed attack, including:
 - a. the targeted critical or important functions and identified ICT systems, processes and technologies supporting the critical or important function, as identified in the red team test plan;
 - b. summary of each scenario;
 - c. flags reached and not reached;
 - d. attack paths followed successfully and unsuccessfully;
 - e. tactics, techniques and procedures used successfully and unsuccessfully;
 - f. deviations from the red team test plan, if any;
 - g. leg-ups granted, if any;
- (b) All actions that the testers are aware of that were performed by the blue team to reconstruct the attack and to mitigate its effects;
- (c) discovered vulnerabilities and other findings, including:
 - a. vulnerability and other finding description including their criticality;
 - b. root cause analysis of successful attacks;
 - c. recommendations for remediation including indication of the remediation priority.

<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>

TIBER GUIDANCE



TIBER GUIDANCE

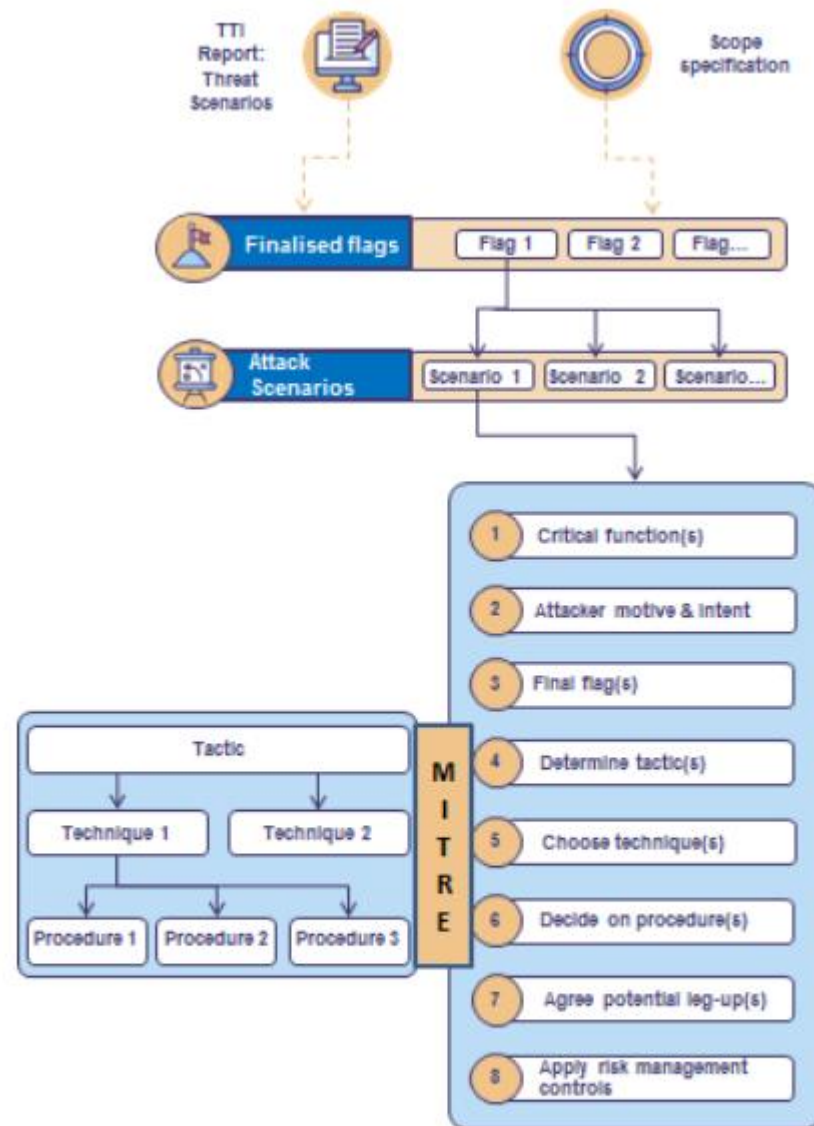


<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>

Source: https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/shared/pdf/Final_TIBER-EU_Guidance_for_Target_Threat_Intelligence_July_2020.pdf

TIBER GUIDANCE

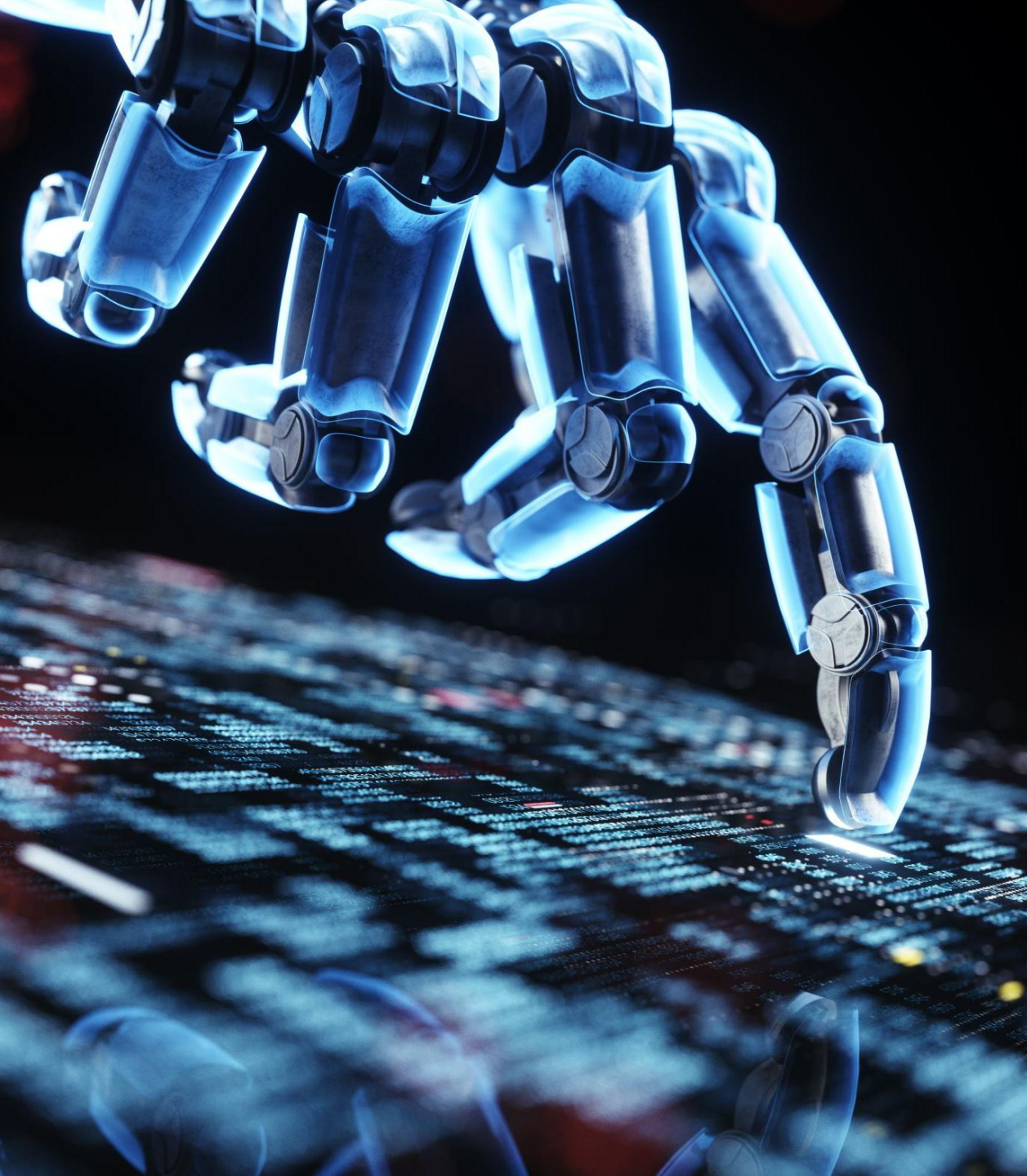
<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>



Source: https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/shared/pdf/Final_TIBER-EU_Guidance_for_the_Red_Team_Test_Plan_July_2020.pdf

ICT providers

- Risk assessment - initial, upon RFP process and when signing the contract
- Continuous monitoring and auditing - KPIs, periodical review, periodical audits
- Contractual obligations - certain specific mandatory obligations to be included.
- Incident management - including the 3rd party in the incident management process
- Exit strategy - detailed overview of steps to be taken in case the vendor has to be changed and/or the application to be migrated and/or the data to be migrated to another application
- Registry of ICT providers – very detailed information about providers



Cyber Resilience Act

Cyber Resilience Act

- EU Regulation – directly applicable in each Member State
- Entrance into force in 2027
- not applicable to medical devices
- not applicable to vehicles

Article 2

Scope

1. This Regulation applies to products with digital elements made available on the market, the intended purpose or reasonably foreseeable use of which includes a direct or indirect logical or physical data connection to a device or network.

(1) 'product with digital elements' means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately;

(2) 'remote data processing' means data processing at a distance for which the software is designed and developed by the manufacturer, or under the responsibility of the manufacturer, and the absence of which would prevent the product with digital elements from performing one of its functions;

(22) 'making available on the market' means the supply of a product with digital elements for distribution or use on the Union market in the course of a commercial activity, whether in return for payment or free of charge;

Cyber Resilience Act

Article 6

Requirements for products with digital elements

Products with digital elements shall be made available on the market only where:

- (a) they meet the essential cybersecurity requirements set out in Part I of Annex I, provided that they are properly installed, maintained, used for their intended purpose or under conditions which can reasonably be foreseen, and, where applicable, the necessary security updates have been installed; and
- (b) the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.

Requirement of a conformity assessment for the following types of products, as set out in Annex III:

Critical products with digital elements - Annex IV – additional requirements

- (a) the product with digital elements primarily performs functions critical to the cybersecurity of other products, networks or services, including securing authentication and access, intrusion prevention and detection, end-point security or network protection;
- (b) the product with digital elements performs a function which carries a significant risk of adverse effects in terms of its intensity and ability to disrupt, control or cause damage to a large number of other products or to the health, security or safety of its users through direct manipulation, such as a central system function, including network management, configuration control, virtualisation or processing of personal data.

Cyber Resilience Act

Article 13

Obligations of manufacturers

1. When placing a product with digital elements on the market, manufacturers shall ensure that it has been designed, developed and produced in accordance with the essential cybersecurity requirements set out in Part I of Annex I.
2. For the purpose of complying with paragraph 1, manufacturers shall undertake an assessment of the cybersecurity risks associated with a product with digital elements and take the outcome of that assessment into account during the planning, design, development, production, delivery and maintenance phases of the product with digital elements with a view to minimising cybersecurity risks, preventing incidents and minimising their impact, including in relation to the health and safety of users.
5. For the purpose of complying with paragraph 1, manufacturers shall exercise due diligence when integrating components sourced from third parties so that those components do not compromise the cybersecurity of the product with digital elements, including when integrating components of free and open-source software that have not been made available on the market in the course of a commercial activity.
6. Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.

- Obligations in case of creating software to comply with cybersecurity requirements (including due diligence for third party components used)
- Obligations throughout the lifecycle of the software in terms of ensuring security thereof

Cyber Resilience Act

Without prejudice to the second subparagraph, the support period shall be at least five years. Where the product with digital elements is expected to be in use for less than five years, the support period shall correspond to the expected use time.

9. Manufacturers shall ensure that each security update, as referred to in Part II, point (8), of Annex I, which has been made available to users during the support period, remains available after it has been issued for a minimum of 10 years or for the remainder of the support period, whichever is longer.

Cyber Resilience Act

Article 14

Reporting obligations of manufacturers

1. A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.
2. For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit:
 - (a) an early warning notification of an actively exploited vulnerability, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, indicating, where applicable, the Member States on the territory of which the manufacturer is aware that their product with digital elements has been made available;
 - (b) unless the relevant information has already been provided, a vulnerability notification, without undue delay and in any event within 72 hours of the manufacturer becoming aware of the actively exploited vulnerability, which shall provide general information, as available, about the product with digital elements concerned, the general nature of the exploit and of the vulnerability concerned as well as any corrective or mitigating measures taken, and corrective or mitigating measures that users can take, and which shall also indicate, where applicable, how sensitive the manufacturer considers the notified information to be;
 - (c) unless the relevant information has already been provided, a final report, no later than 14 days after a corrective or mitigating measure is available, including at least the following:
 - (i) a description of the vulnerability, including its severity and impact;
 - (ii) where available, information concerning any malicious actor that has exploited or that is exploiting the vulnerability;
 - (iii) details about the security update or other corrective measures that have been made available to remedy the vulnerability.

Obligation of software manufacturers to report vulnerabilities in the software they created

Cyber Resilience Act

Obligation of the manufacturer of software to report any security incident concerning the software it created

3. A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16.

4. For the purposes of the notification referred to in paragraph 3, the manufacturer shall submit:

- (a) an early warning notification of a severe incident having an impact on the security of the product with digital elements, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, including at least whether the incident is suspected of being caused by unlawful or malicious acts, which shall also indicate, where applicable, the Member States on the territory of which the manufacturer is aware that their product with digital elements has been made available;
- (b) unless the relevant information has already been provided, an incident notification, without undue delay and in any event within 72 hours of the manufacturer becoming aware of the incident, which shall provide general information, where available, about the nature of the incident, an initial assessment of the incident, as well as any corrective or mitigating measures taken, and corrective or mitigating measures that users can take, and which shall also indicate, where applicable, how sensitive the manufacturer considers the notified information to be;
- (c) unless the relevant information has already been provided, a final report, within one month after the submission of the incident notification under point (b), including at least the following:
 - (i) a detailed description of the incident, including its severity and impact;
 - (ii) the type of threat or root cause that is likely to have triggered the incident;
 - (iii) applied and ongoing mitigation measures.

5. For the purposes of paragraph 3, an incident having an impact on the security of the product with digital elements shall be considered to be severe where:

- (a) it negatively affects or is capable of negatively affecting the ability of a product with digital elements to protect the availability, authenticity, integrity or confidentiality of sensitive or important data or functions; or
- (b) it has led or is capable of leading to the introduction or execution of malicious code in a product with digital elements or in the network and information systems of a user of the product with digital elements.

Cyber Resilience Act

Article 15

Voluntary reporting

1. Manufacturers as well as other natural or legal persons may notify any vulnerability contained in a product with digital elements as well as cyber threats that could affect the risk profile of a product with digital elements on a voluntary basis to a CSIRT designated as coordinator or ENISA.
2. Manufacturers as well as other natural or legal persons may notify any incident having an impact on the security of the product with digital elements as well as near misses that could have resulted in such an incident on a voluntary basis to a CSIRT designated as coordinator or ENISA.
3. The CSIRT designated as coordinator or ENISA shall process the notifications referred to in paragraphs 1 and 2 of this Article in accordance with the procedure laid down in Article 16.

The CSIRT designated as coordinator may prioritise the processing of mandatory notifications over voluntary notifications.

4. Where a natural or legal person other than the manufacturer notifies an actively exploited vulnerability or a severe incident having an impact on the security of a product with digital elements in accordance with paragraph 1 or 2, the CSIRT designated as coordinator shall without undue delay inform the manufacturer.

Obligation to report
vulnerabilities in their
software

Cyber Resilience Act

Article 19

Obligations of importers

1. Importers shall place on the market only products with digital elements that comply with the essential cybersecurity requirements set out in Part I of Annex I and where the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.
2. Before placing a product with digital elements on the market, importers shall ensure that:
 - (a) the appropriate conformity assessment procedures as referred to in Article 32 have been carried out by the manufacturer;
 - (b) the manufacturer has drawn up the technical documentation;
 - (c) the product with digital elements bears the CE marking referred to in Article 30 and is accompanied by the EU declaration of conformity referred to in Article 13(20) and the information and instructions to the user as set out in Annex II in a language which can be easily understood by users and market surveillance authorities;
 - (d) the manufacturer has complied with the requirements set out in Article 13(15), (16) and (19).

For the purposes of this paragraph, importers shall be able to provide the necessary documents proving the fulfilment of the requirements set out in this Article.

3. Where an importer considers or has reason to believe that a product with digital elements or the processes put in place by the manufacturer are not in conformity with this Regulation, the importer shall not place the product on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation. Furthermore, where the product with digital elements presents a significant cybersecurity risk, the importer shall inform the manufacturer and the market surveillance authorities to that effect.

Where an importer has reason to believe that a product with digital elements may present a significant cybersecurity risk in light of non-technical risk factors, the importer shall inform the market surveillance authorities to that effect. Upon receipt of such information, the market surveillance authorities shall follow the procedures referred to in Article 54(2).

Importers of software from third countries (outside the EU) have to ensure that these comply with proper cybersecurity requirements, as outlined in the Cyber Resilience Act

Cyber Resilience Act

Article 20

Obligations of distributors

1. When making a product with digital elements available on the market, distributors shall act with due care in relation to the requirements set out in this Regulation.
2. Before making a product with digital elements available on the market, distributors shall verify that:
 - (a) the product with digital elements bears the CE marking;
 - (b) the manufacturer and the importer have complied with the obligations set out in Article 13(15), (16), (18), (19) and (20) and Article 19(4), and have provided all necessary documents to the distributor.
3. Where a distributor considers or has reason to believe, on the basis of information in its possession, that a product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I, the distributor shall not make the product with digital elements available on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation. Furthermore, where the product with digital elements poses a significant cybersecurity risk, the distributor shall inform, without undue delay, the manufacturer and the market surveillance authorities to that effect.

Distributors of software from third countries (outside the EU) have to ensure that these comply with proper cybersecurity requirements, as outlined in the Cyber Resilience Act

Cyber Resilience Act

Article 24

Obligations of open-source software stewards

1. Open-source software stewards shall put in place and document in a verifiable manner a cybersecurity policy to foster the development of a secure product with digital elements as well as an effective handling of vulnerabilities by the developers of that product. That policy shall also foster the voluntary reporting of vulnerabilities as laid down in Article 15 by the developers of that product and take into account the specific nature of the open-source software steward and the legal and organisational arrangements to which it is subject. That policy shall, in particular, include aspects related to documenting, addressing and remediating vulnerabilities and promote the sharing of information concerning discovered vulnerabilities within the open-source community.

2. Open-source software stewards shall cooperate with the market surveillance authorities, at their request, with a view to mitigating the cybersecurity risks posed by a product with digital elements qualifying as free and open-source software.

Further to a reasoned request from a market surveillance authority, open-source software stewards shall provide that authority, in a language which can be easily understood by that authority, with the documentation referred to in paragraph 1, in paper or electronic form.

3. The obligations laid down in Article 14(1) shall apply to open-source software stewards to the extent that they are involved in the development of the products with digital elements. The obligations laid down in Article 14(3) and (8) shall apply to open-source software stewards to the extent that severe incidents having an impact on the security of products with digital elements affect network and information systems provided by the open-source software stewards for the development of such products.

Article 25

Security attestation of free and open-source software

In order to facilitate the due diligence obligation set out in Article 13(5), in particular as regards manufacturers that integrate free and open-source software components in their products with digital elements, the Commission is empowered to adopt delegated acts in accordance with Article 61 to supplement this Regulation by establishing voluntary security attestation programmes allowing the developers or users of products with digital elements qualifying as free and open-source software as well as other third parties to assess the conformity of such products with all or certain essential cybersecurity requirements or other obligations laid down in this Regulation.

Open source software –
cyber security
requirements

ANNEX I

ESSENTIAL CYBERSECURITY REQUIREMENTS

Part I Cybersecurity requirements relating to the properties of products with digital elements

- (1) Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.
- (2) On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:
 - (a) be made available on the market without known exploitable vulnerabilities;
 - (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;
 - (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;
 - (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;
 - (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
 - (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
 - (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

Cyber Resilience Act

Essential cybersecurity
requirements – procedural,
technical, operational

Cyber Resilience Act

- (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;
- (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
- (j) be designed, developed and produced to limit attack surfaces, including external interfaces;
- (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
- (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;
- (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Part II Vulnerability handling requirements

Manufacturers of products with digital elements shall:

- (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

Essential cybersecurity requirements – procedural, technical, operational

Cyber Resilience Act

- (2) in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;
- (3) apply effective and regular tests and reviews of the security of the product with digital elements;
- (4) once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;
- (5) put in place and enforce a policy on coordinated vulnerability disclosure;
- (6) take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;
- (7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;
- (8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

Essential cybersecurity requirements – procedural, technical, operational



Question?

Thank you!